# Margins365 spec v20.1 — Developer change pack (K59–K90) and gap audit

**Version 20.1 — 11 November 2026, 20:55 Europe/London.** Adds the gap audit below (every requirement checked against the live site and the server code), the release gate RG-1–RG-4 and proposed decisions K91–K94 (awaiting Akthar). Everything from v20 (K59–K90) stands.

**Status: APPROVED — Akthar Uddin, 11 November 2026, 13:36 Europe/London, with his follow-up decisions the same afternoon (founding offer 6 months; Sample shop buttons and full product architecture delegated to the Business & Product Agent). For:** Design & Development. **Baseline:** FINAL v19 (K1–K58) and the 7 November 2026 Help centre and footer handoff, which K64 and K65 replace. **Companion:** `/workspace/v20.1/Margins365-Spec-v20.1.md` (full spec, section 23 holds the product architecture). Legal documents: `/workspace/v20.1/Margins365-*-v20.md`.

Requirements and acceptance criteria only: no code, no UI design. Formulas in spec 12.0–12.3 do not change. Prices and order limits do not change. Nothing here goes to Marketing until it is built and tested.

**Will QA make the changes? No.** Developers build everything in this pack. QA then tests the built site with `/workspace/v20.1/Margins365-QA-Prompt-v20.1` and reports failures back to Development. See “Hand to QA when”.

## Gap audit 11 Nov 2026

**Why.** Akthar found that cancellation did not work and emails were missing (K89, K90). This audit checks every requirement in Spec v20.1 (sections 3–23, K1–K90 and the legal documents) against the live site so the developers fix everything in one pass.

**How it was checked (20:45–20:55 Europe/London).** The live app code (`index-BWGxRavO.js`, the version live at 20:45), safe probes of margins365.com with no account and no messages sent, and the server code copy dated 11 Nov 13:38. The live server has routes the copy does not (contact, founding, shops, team), so items marked “Unverifiable from outside” must be confirmed by the developers with current server code and Stripe test mode. **Akthar: please ask the developers for the current server code** so these can be closed.

**Status meanings.** Built and server-backed = works and is saved on the server. Browser-only = looks as if it works but only changes this browser (fake). Missing = not there. Partial = some parts work. Unverifiable from outside = needs staging, Stripe or SES access.

**Severity.** P0 = money, security or legal. P1 = broken feature. P2 = cosmetic or minor.

**Type.** Every gap below is “Not built — existing requirement”: the spec already required it and it was not built (no new decision needed). Where a gap repeats a K item (K83–K90), that item is named in

the requirement. The four items that need a new decision are K91–K94, below; they are proposals, not approvals.

### Counts

| Live status | Gaps |
|---|---|
| Browser-only | 10 |
| Missing | 24 |
| Partial | 23 |
| Unverifiable from outside | 9 |
| **Total gaps** | **66** |
| Built and server-backed (checked this pass, listed at the end) | 14 areas |

| Severity | Gaps |
|---|---|
| P0 | 23 |
| P1 | 31 |
| P2 | 12 |

### Release gate (v20.1) — nothing ships to customers until this passes

**RG-1 Fake-success ban.** No screen, pop-up, banner, message or email may say an action worked unless the server has stored it and, where money or a subscription is involved, Stripe has confirmed it. On any failure the app shows an error, changes nothing and offers Try again. Browser-only or “demo” fallbacks for sign-in, verification, password reset, billing, cancellation, shops, seats or product data are not allowed in production.

**RG-2 Server-backed check for every state-changing action.** For each action below QA records: the server request in the network log, the stored record (or the admin view), the Stripe Dashboard object where money is involved, the email received through SES where one is required, an audit entry, and the same result on a second device or private window. An action passes only if all apply.

| Action | Server record | Stripe (test mode) | Email (SES) |
|---|---|---|---|
| Sign up, verify email, sign in (email and Google), password | User, session, token | — | Verify, reset, password |

| Action | Server record | Stripe (test mode) | Email (SES) |
|---|---|---|---|
| reset and change | | | changed, Google-only |
| Save profile and business Info | User and account (all Info fields) | — | — |
| Start trial (each plan, monthly and annual, founding and normal) | Account plan, trial end, founding place | Subscription trialing, trial_end, price, coupon | Trial started (K90) |
| Change plan, change interval | Plan, next charge | Subscription price, proration or schedule | Plan change (if K93 approved) |
| Update card, view invoices | — | Stripe-hosted page, payment method | Receipt (Link/Stripe) |
| Cancel, resubscribe | Cancellation record, audit | cancel_at_period_end, no upcoming invoice | Cancellation (K89) |
| Upload and import, edit costs, ads, overheads, saved datasets, scenarios, Start fresh, Clear sample data | Product data per shop, order usage | — | 80% warning when crossed |
| Add, rename, remove, switch shop | Shops and per-shop data | — | — |
| Invite, revoke, accept, remove member | Invites, memberships, sessions | — | Invitation, removed |
| Download my data | Export built on the server | — | — |
| Contact us, Suggest a feature | Stored message | — | Notification to info.marginos@gmail.com, visitor confirmation |
| Payment failed, refund, access end (system) | State, deletion job, tombstone | Invoice, refund, subscription ended | Payment failed, data deleted |

**RG-3 Browser storage allowlist.** The browser may keep only display preferences, the cookie-consent choice and a cache that is cleared at sign-out and account closure. Anything else found in

localStorage (product data, plan state, cancellation, audit, Info fields, tokens) fails the release.

**RG-4 End-to-end matrix.** Suite E2E in the QA Prompt v20.1 passes with real Stripe test-mode accounts, checking the Stripe Dashboard and SES email receipt for every flow, before any live-mode trial is taken.

### Every gap

| ID | Area | Requirement (spec ref) | Live status | Evidence | Sev | Fix — acceptance criteria | Owner |
|---|---|---|---|---|---|---|---|
| GA-01 | Billing | Cancel trial / subscription reaches Stripe (12.5A, 23.10, K89) | Browser-only | Confirm cancel only changes browser state; no cancel route (8 probes return 405 like a made-up address); Stripe stays Trialing and would charge | P0 | Stripe shows cancel_at_period_end (or canceled) and no upcoming invoice before any success; pop-up, email, status on every device (K89 CX-1–CX-9) | Dev (server + front end) |
| GA-02 | Billing | Trial is 14 days, set by the server (K38, 12.5) | Partial | Server copy uses the trial length sent by the browser (`trialDays` in the request body); the browser sends 14, but any value is accepted | P0 | The server always creates a 14-day trial and ignores any trial length from the browser; a request with 60 days still gives 14 in Stripe | Dev (server) |
| GA-03 | Billing | One trial per account; per card by default (23.9, K40) | Browser-only | The “already used its free trial” check runs only in the browser; the server copy creates Checkout without checking | P0 | The server refuses a second trial for the same account (and the same card fingerprint by default) with a clear message; a direct API call is refused too | Dev (server) |

| ID | Area | Requirement (spec ref) | Live status | Evidence | Sev | Fix — acceptance criteria | Owner |
|---|---|---|---|---|---|---|---|
| GA-04 | Billing | No second subscription for an account that already has one (12.10 duplicate Checkout) | Browser-only | “You already have an active plan” is checked only in the browser; the server copy creates a new Checkout for any signed-in user | P0 | The server refuses Checkout when the account has a trialing, active or past-due subscription; two parallel Checkouts give one subscription | Dev (server) |
| GA-05 | Billing | Founding price charged at Checkout: 50% for 6 monthly payments, 25% off the first annual year (12.5C, K72) | Unverifiable from outside | Pricing shows £19.50 etc.; the browser sends `founding: true`; the server copy ignores it and applies no coupon. Live server may differ | P0 | The server (not the browser) decides eligibility and applies the Stripe coupon; Checkout, the first invoice and Plan & billing show the founding amount to the penny; month 7 / year 2 is the full price | Dev (server) |
| GA-06 | Billing | Founding places: first 100 paying users, safe under parallel Checkouts (FO-1–FO-7) | Unverifiable from outside | `/api/founding` returns cap 100, sold 0 from the server; no code seen that counts a place on payment or reserves it safely | P0 | A place is counted once, atomically, at the point K72 defines; the 101st parallel Checkout gets the normal price; the Pricing counter equals the database count | Dev (server) |
| GA-07 | Billing | Stripe events update the account (12.10) | Partial | Handles checkout completed, subscription updated (ignores cancel_at_period_end) and deleted (sets the retired “free” plan); no invoice.paid, invoice.payment_failed, trial_will_end or | P0 | Every event in 12.10 maps to the documented state; no “free” plan; past-due, cancel scheduled and ended states shown in Plan & billing; replays are ignored | Dev (server) |

| ID | Area | Requirement (spec ref) | Live status | Evidence | Sev | Fix — acceptance criteria | Owner |
|---|---|---|---|---|---|---|---|
| | | | | payment-action events | | | |
| GA-08 | Billing | Change plan: upgrade (prorated) and downgrade (at renewal); trial change keeps end date, no charge (23.8, 12.4, K69) | Missing | Change plan opens the plans pop-up; choosing a plan shows “You already have an active plan”; no server plan-change route | P1 | Owner can upgrade and downgrade; Stripe shows the new price with proration (paid) or the new day-15 amount (trial); limits change only after Stripe confirms | Dev (server + front end) |
| GA-09 | Billing | Change between monthly and annual at renewal (23.8) | Missing | No interval change anywhere in the app | P1 | Interval change is scheduled for renewal and shown in Plan & billing and Stripe | Dev (server + front end) |
| GA-10 | Billing | Payment method and invoices through a Stripe-hosted page (12.10, 23.8) | Missing | No Update card or Invoices control; `/api/billing/portal` does not exist | P1 | Plan & billing opens a Stripe-hosted page for card and invoices and returns to Plan & billing; cancellation stays in Plan & billing | Dev (server + front end) |
| GA-11 | Billing | Paid access end date comes from Stripe (12.5A) | Browser-only | Browser cancel uses “now + 30 days” when it has no period end | P0 | Access end equals Stripe current_period_end (paid) or trial_end; never estimated | Dev (server + front end) |
| GA-12 | Billing | Plan status is looked up reliably (12.10) | Partial | Server copy finds the plan by scanning the last 40 completed Checkouts of all customers; after 40 sign-ups an account can lose its plan if a webhook was missed | P1 | Plan is read from the stored Stripe customer and subscription IDs for that account | Dev (server) |

| ID | Area | Requirement (spec ref) | Live status | Evidence | Sev | Fix — acceptance criteria | Owner |
|---|---|---|---|---|---|---|---|
| GA-13 | Billing | Daily Stripe ↔ account reconciliation with alerts (12.10) | Missing | No scheduled job in the server code | P1 | A daily job compares every subscription with the account record and alerts on mismatches | Dev (server) |
| GA-14 | Billing | Refund ends access and schedules deletion per policy (12.5, 12.6) | Partial | Refund or lost dispute sets the retired “free” plan | P0 | A refund under the policy ends access and schedules the wipe with dated notice; no “free” plan | Dev (server) |
| GA-15 | Security | Stripe return addresses fixed by the server (12.10) | Partial | Server copy takes success and cancel URLs from the browser | P1 | Server sets margins365.com return URLs; a request with another address is ignored | Dev (server) |
| GA-16 | Legal | Legal acceptance recorded: document, version, time (K74, LG, 23.13) | Missing | No acceptance step or record at sign-up or Checkout; Checkout code has no terms consent | P0 | Sign-up/Checkout records the Terms and Refunds version accepted with a timestamp; Checkout shows the links; the trial email links to them | Dev (server + front end) |
| GA-17 | Email | Trial started email (23.12, K90) | Missing | Server sends only verification and password emails | P0 | K90 TS-1–TS-5 | Dev (server) |
| GA-18 | Email | Trial reminder 3 days before the end (12.5A) | Missing | No scheduler and no trial_will_end handling | P0 | One reminder per trial, 3 days before, with plan, amount, date and Plan & billing link; none after cancel | Dev (server) |
| GA-19 | Email | Payment receipt and | Unverifiable | Depends on Stripe/Link email | P1 | A test conversion produces a receipt | Akthar |

| ID | Area | Requirement (spec ref) | Live status | Evidence | Sev | Fix — acceptance criteria | Owner |
|---|---|---|---|---|---|---|---|
| | | invoice (Link/Stripe) (23.12) | from outside | settings | | with the Margins365 name and VAT-inclusive amount | |
| GA-20 | Email | Payment failed / final failure (S7, 23.12) | Missing | No invoice.payment_failed handling, no email | P0 | Each failed charge sends the email with update-card link; final failure ends access with dated deletion notice | Dev (server) |
| GA-21 | Email | Cancellation confirmation (12.5A, K89) | Missing | No email exists | P0 | K89 CX-3 | Dev (server) |
| GA-22 | Email | Founding price ends soon, 14 days before month 6 ends (K72) | Missing | No scheduler | P0 | Founding accounts get one notice 14 days before the price rises, with both amounts and the date | Dev (server) |
| GA-23 | Email | 80% of order limit, owner and members (12.4) | Missing | Usage is counted only in the browser; no email | P1 | First crossing of 80% in a billing month sends one email to owner and members | Dev (server) |
| GA-24 | Email | Data deleted email when the wipe runs (12.6) | Missing | No wipe job, no email | P1 | Sent once after the wipe; states what was deleted; contains no data | Dev (server) |
| GA-25 | Email | Members get the dated warning when the owner cancels (23.3, 23.10) | Missing | No member list and no email | P1 | Every active member gets the dated notice once | Dev (server) |
| GA-26 | Email | Seat invitation email (23.3 | Missing | Team screen says “Invite saved on the | P1 | Invite email with Accept link to | Dev |

| ID | Area | Requirement (spec ref) | Live status | Evidence | Sev | Fix — acceptance criteria | Owner |
|---|---|---|---|---|---|---|---|
| | | ST-2) | | server… Email delivery follows the seats EML suite.” — no email | | /invite/:token arrives via SES; single use, 7 days | (server) |
| GA-27 | Email | “You no longer have access” when a member is removed (23.3) | Missing | No remove-member function | P1 | Removal sends the email and ends their sessions at once | Dev (server) |
| GA-28 | Email | Contact notification and visitor confirmation (23.11, K84, K88) | Unverifiable from outside | `/api/contact` exists; not sent from outside (no real messages); pop-up still says “can’t promise a reply time” | P1 | A real test message reaches info.marginos@gmail.com with Reply-To the visitor; confirmation has the K88 sentence and no message text | Dev (server + front end) |
| GA-29 | Email | Suggest a feature emailed to info.marginos@gmail.com (K83) | Unverifiable from outside | Route needs sign-in; server copy stores only | P1 | A test suggestion arrives with every K83 field and Reply-To the submitter | Dev (server) |
| GA-30 | Email | Brand “Margins365” in every email (K59) | Partial | Server copy: verification, reset and password emails say “Margins 365” | P2 | Every subject and body says Margins365 | Dev (server) |
| GA-31 | Email | No email asks for a reply to support (K86) | Partial | “Your password was changed” says “reply to this email or contact support from the privacy policy contact address” | P2 | Wording points to Help centre Contact us; Reply-To follows K86 | Dev (server) |
| GA-32 | Email | SES production access, DKIM, | Unverifiable | Health check says SES configured; sandbox | P0 | K86 proof attached: SES identity verified, | Akthar |

| ID | Area | Requirement (spec ref) | Live status | Evidence | Sev | Fix — acceptance criteria | Owner |
|---|---|---|---|---|---|---|---|
| | | MAIL FROM, SPF, DMARC proof (K86) | from outside | status and DNS proof not shown | | production access, headers pass SPF/DKIM/DMARC at Gmail, Outlook, iCloud | |
| GA-33 | Security | Password reset link always on margins365.com (5.1, K57) | Partial | Server copy builds the reset link from an address the browser sends (`origin`); an attacker could make the email link point to another site | P0 | The server builds every email link from a fixed margins365.com address; a request with another origin still produces a margins365.com link | Dev (server) |
| GA-34 | Security | No pretend sign-in, reset or verification when the server fails (fake-success ban) | Browser-only | If the request fails, the app falls back to a browser demo: “Signed in”, “Verification email sent”, reset success, with no server | P0 | On any server or network failure, show an error and stay signed out; remove every demo fallback | Dev (front end) |
| GA-35 | Security | Google sign-in verified for this app (5.1) | Partial | Server copy accepts a Google access token and reads the profile without checking it was issued to Margins365 | P1 | Server verifies a Google ID token whose audience is the Margins365 client ID; tokens for other apps are refused | Dev (server) |
| GA-36 | Security | Rate limits shared and durable (23.19.5, 5.1) | Partial | Server copy keeps sign-in and reset limits in memory per server; they reset on restart and are not shared | P1 | Limits are held in shared storage and survive restarts and multiple servers | Dev (server) |
| GA-37 | Security | Audit log on the server (12.10, 23.0, K89) | Browser-only | Audit events are kept in the browser (`marginos.audit.v1`, 200 events) | P1 | Security, billing and admin events are written on the server and readable only by | Dev (server) |

| ID | Area | Requirement (spec ref) | Live status | Evidence | Sev | Fix — acceptance criteria | Owner |
|---|---|---|---|---|---|---|---|
| | | | | | | admins | |
| GA-38 | Security | Health endpoint shows no configuration detail | Partial | `/api/health` publicly shows database, Stripe and SES configuration flags and region | P2 | Public health check returns only ok | Dev (server) |
| GA-39 | Security | security.txt and stricter CSP (SEC suite) | Partial | No /.well-known/security.txt; CSP allows inline scripts | P2 | security.txt published; inline scripts removed or hashed | Dev (server + front end) |
| GA-40 | Data | Product data stored on the server, per shop (F1, 23.13) | Browser-only | Order rows, costs, ads, saved datasets and scenarios are saved in the browser (`marginos.v6` and per-user keys); no upload or data routes (404) | P0 | All product data is stored server-side per account and shop; another device shows the same data; browser holds only preferences and a cache cleared at sign-out | Dev (server + front end) |
| GA-41 | Data | Hard monthly order limits enforced on the server (12.4, 12.4A) | Browser-only | Unique orders are counted in the browser from local data; clearing storage resets the count | P0 | The server counts unique orders per account and period and blocks over-limit imports (12.4A tests); browser changes cannot bypass it | Dev (server) |
| GA-42 | Data | Data wiped when access ends; backups within 7 days (K39, 12.6, 18, 19) | Missing | No deletion job; data stays in the browser; account remains with a “free” plan | P0 | An idempotent deletion job wipes every store at access end, writes a tombstone and sends the email; backups age out within 7 days | Dev (server) |

| ID | Area | Requirement (spec ref) | Live status | Evidence | Sev | Fix — acceptance criteria | Owner |
|---|---|---|---|---|---|---|---|
| GA-43 | Data | Account closes at access end; members lose access (K51) | Missing | No closure; webhook sets a “free” plan | P0 | At access end the account and memberships close; sign-in explains the account is closed; a later sign-up starts empty | Dev (server) |
| GA-44 | Legal | Privacy Policy matches what the product does (Privacy v20.1) | Partial | Policy says data is held at DigitalOcean London; live product data is in the browser (GA-40) | P0 | GA-40 and GA-42 are built before launch, so the policy is true; no policy change needed | Dev (server + front end) |
| GA-45 | Data | Download my data (CSV) for all the account’s shops, owner and members (12.6, 23.3) | Partial | CSV is built from data in this browser only | P1 | Export is built on the server from all shops; same file on any device and for members | Dev (server + front end) |
| GA-46 | Data | Business Info saved on the server: country, address, VAT number, website (K70, 23.4) | Browser-only | Name, business name and phone go to the server; country, address, VAT number and website only to the browser (`m365_info_extra`) | P1 | All Info fields saved on the server; members see them read-only | Dev (server + front end) |
| GA-47 | Data | Cancellation reason stored on the server (K71, CA-2) | Browser-only | Saved in the browser (`m365_cancel_reasons`) | P1 | Reason saved on the server with the 23.13 retention | Dev (server) |
| GA-48 | Data | Privacy requests: export and deletion handled within | Missing | No admin tool to find, export or delete an account | P1 | An admin can export and delete one account on request, logged | Dev (server) |

| ID | Area | Requirement (spec ref) | Live status | Evidence | Sev | Fix — acceptance criteria | Owner |
|---|---|---|---|---|---|---|---|
| | | one month (Privacy v20.1) | | | | | |
| GA-49 | Shops | Shops: add, rename, remove, switch, per-shop data (23.2 SH-1–SH-7) | Partial | Add, rename and remove call `/api/shops` (server, sign-in required); no shop switcher; shop data lives in the browser | P1 | Owner can switch shops; each shop’s data is separate on the server; removal deletes that shop’s server data after confirmation | Dev (server + front end) |
| GA-50 | Seats | Invite, accept, members list, remove, roles and permissions (23.3 ST-1–ST-7) | Missing | Invites are saved on the server, but `/invite/:token` is a 404, there is no members list or remove, and members cannot see shared data | P1 | ST-1–ST-7 pass: accept with the same verified email, members see account data, owner-only actions refused for members (403) | Dev (server + front end) |
| GA-51 | Copy | No developer wording on screens (15.4) | Partial | Team screen: “Email delivery follows the seats EML suite”, “Pending invites are stored on the server” | P2 | Customer wording only | Dev (front end) |
| GA-52 | Billing | Plan & billing shows plan, interval, status, next charge date and amount, founding end, usage, shops and seats (23.8) | Partial | Shows “Access: trial · Plan: pro · Features: …” | P1 | Every 23.8 item shown from server data, amounts matching Stripe | Dev (server + front end) |
| GA-53 | Billing | Members see “Only the account owner can manage billing.” (23.8 | Missing | Text not in the app | P1 | Member opening /account/billing sees the message; billing APIs refuse members | Dev (server + front end) |

| ID | Area | Requirement (spec ref) | Live status | Evidence | Sev | Fix — acceptance criteria | Owner |
|---|---|---|---|---|---|---|---|
| | | PB-1) | | | | | |
| GA-54 | Copy | Trial banner shows first payment amount, date and founding wording (23.9) | Partial | Banner shows only “You’re on your [Plan] free trial until [date].” | P2 | Banner shows the 23.9 sentence | Dev (front end) |
| GA-55 | Copy | No “Cancel before day 14 and pay nothing” (K81, K87) | Partial | Still in 3 places (trial line, plan text, Plan & billing) | P1 | Use “Cancel before your trial ends on [date] and pay nothing” | Dev (front end) |
| GA-56 | Copy | Contact wording “Thank you for contacting us, we aim to respond within 24 hours.” (K88) | Missing | Pop-up still says “We read every message, but we can’t promise a reply time.” | P2 | K88 HELP-33–HELP-37 | Dev (server + front end) |
| GA-57 | Billing | Trial-start confirmation on screen (K90) | Missing | Return from Checkout opens the app with no confirmation | P1 | K90 TS-4 | Dev (front end) |
| GA-58 | Copy | Retired “Keep Pro” code and Free-plan wording removed (K69, v18 Free plan retired) | Partial | A browser-only “Keep Pro” plan change is still in the code (not shown); 3 screens still say “Free upload” (“Start fresh does not restore Free uploads for today.”) | P2 | No Keep Pro code; no Free-plan or Free-upload wording (PUB-14) | Dev (front end) |
| GA-59 | Routes | Routes /sign-in, /reset-password, /welcome, | Missing | All four return 404; the reset link uses /?reset= | P1 | Each route works on refresh; reset and invite emails link to | Dev (front end) |

| ID | Area | Requirement (spec ref) | Live status | Evidence | Sev | Fix — acceptance criteria | Owner |
|---|---|---|---|---|---|---|---|
| | | /invite/:token (23.1, K63) | | | | them | |
| GA-60 | SEO | Phase 2 calculator and landing pages wait for their release gate (K76, K77, exit criterion 15) | Partial | Six Phase 2 pages are live and listed in sitemap.xml before PCALC and SEO-34–36 have passed | P1 | Remove from sitemap and set noindex until the gate passes, or pass PCALC now | Dev (server + front end) |
| GA-61 | SEO | Share image and favicon (SEO spec) | Missing | Pages declare a large share card but have no og:image; /favicon.ico is 404 | P2 | og:image on every public page; /favicon.ico served | Dev (front end) |
| GA-62 | SEO | Prerendered content for legal and Sample shop pages (K75) | Partial | Legal pages prerender only a title and one line; full text needs JavaScript | P2 | Prerendered HTML contains the full page text | Dev (front end) |
| GA-63 | SEO | sitemap.xml served as XML; mixed-case URLs resolve; 404 has no canonical (SEO, NAV-16) | Partial | sitemap content type is application/octet-stream; /Pricing is 404; 404 pages carry a canonical; unknown /api GETs return the HTML 404 | P2 | application/xml; case-insensitive redirect; no canonical on 404; JSON 404 for /api | Dev (front end) |
| GA-64 | Mobile | Pop-ups scroll on phones, banner removed, pages open at the top (K80–K82) | Unverifiable from outside | Not re-tested on this bundle; last test (17:30) failed (G14–G16) | P1 | MOB-01–MOB-13 and NAV-33–NAV-36 pass on a real iPhone, Android and iPad | QA |
| GA-65 | Ops | Admin inbox for contact messages, | Unverifiable from outside | No admin route visible | P2 | Owner-only admin view; 12-month | Dev (server) |

| ID | Area | Requirement (spec ref) | Live status | Evidence | Sev | Fix — acceptance criteria | Owner |
|---|---|---|---|---|---|---|---|
| | | deleted after 12 months (23.11) | | | | deletion job | |
| GA-66 | Ops | Backups and scheduled clean-up (19) | Unverifiable from outside | Not visible from outside | P1 | Backup schedule, 7-day expiry and restore test documented and proven | Dev (server) |

Every gap has a QA test GAP-nn with the same number (QA Prompt v20.1, suite GAP).

### Fix order

1. **Stop the money and legal risks first (P0):** GA-01–GA-07, GA-11, GA-14, GA-16 (billing truth in Stripe), GA-33–GA-34 (sign-in safety), GA-17–GA-22 and GA-32 (required emails, SES proof), GA-40–GA-44 (data on the server, limits, wipe, closure).
2. **Then broken features (P1):** plan change and billing page (GA-08–GA-10, GA-12–GA-13, GA-52–GA-53, GA-57), shops and seats (GA-45–GA-50, GA-23–GA-27), security (GA-15, GA-35–GA-37), routes and Phase 2 gate (GA-59–GA-60), emails to confirm (GA-19, GA-28–GA-29), mobile re-test (GA-64), backups (GA-66), wording (GA-55).
3. **Then P2 polish:** the rest.

### Proposed decisions — need Akthar's approval (not approved)

| ID | Decision needed | Recommendation | Gaps |
|---|---|---|---|
| K91 | Pause live sign-ups and live-mode trials until every P0 in the gap audit is closed | Recommended: **yes**. Keep the site public but run Checkout in Stripe test mode (or show “Opening soon”) so no real customer is charged without cancel, emails or limits working. | GA-01–GA-07, GA-17–GA-22, GA-40–GA-44 |
| K92 | Turn on Stripe’s own customer emails (receipts, failed payment, upcoming renewal, trial ending) as a stop-gap until the SES emails are built | Recommended: **yes, as a stop-gap**. Note Stripe’s trial-ending email is sent 7 days before, not 3; the 12.5A reminder still has to be built. | GA-18, GA-19, GA-20 |
| K93 | Send a plan-change confirmation | Recommended: **yes** — plan, old and new price, | GA-08, |

| ID | Decision needed | Recommendation | Gaps |
|---|---|---|---|
| | email (not in the spec today) | when it takes effect, next charge. | GA-09 |
| K94 | Self-serve “Delete my account now” before access ends (not in the spec today) | Recommended: **not at launch**; handle requests through the privacy contact with the admin tool in GA-48. | GA-48 |

### Only Akthar can do these

1. **Today:** cancel your own test trial in Stripe and check there is no upcoming invoice (spec 23.21.3).
2. **Decide K91–K94** (above).
3. **Stripe Dashboard:** - Webhook endpoint subscribed to: checkout.session.completed, customer.subscription.created / updated / deleted / trial_will_end, invoice.paid, invoice.payment_failed, invoice.payment_action_required, charge.refunded, charge.dispute.closed. - Founding coupons exist (50% for 6 monthly invoices; 25% once for annual) in test and live mode. - Customer portal: card update and invoices on, cancellation off (cancel stays in Plan & billing). - Public details: Terms and Privacy URLs set (needed for terms consent at Checkout). - If K92 is approved: Billing → customer emails on.
4. **AWS SES:** production access approved; margins365.com identity, DKIM and MAIL FROM “Successful”; send the screenshots (K86).
5. **Cloudflare DNS:** apex SPF `v=spf1 include:amazonses.com ~all`, DMARC with a reporting address, MAIL FROM records (EML-24).
6. **Read info.marginos@gmail.com every day, weekends included** (the 24-hour aim, K88).
7. **Send one real Contact us message and one Suggest a feature** (signed in) and confirm both arrive. We do not send real messages.
8. **Ask the developers for the current server code** and give QA a staging site, Stripe test-mode access and test inboxes.
9. **Company details** for the site and legal pages if required: registered address, company number, ICO number.
10. **At launch:** verify Google Search Console and Bing (SEO).

### Verified as built and server-backed (this pass)

| Area | What was confirmed |
|---|---|
| Security headers | HSTS (preload), CSP, X-Frame-Options DENY, nosniff, Referrer-Policy, Permissions-Policy on HTML responses (G10 closed) |
| Routes and 404 | Real routes for public, app and account pages; refresh keeps the page; unknown pages return 404; robots.txt and sitemap.xml served (G1 closed) |
| SEO basics | Titles, descriptions, canonicals and Open Graph text on public pages; FAQPage |

| Area | What was confirmed |
| --- | --- |
| | structured data with 15 questions on Pricing |
| Consent and analytics | Cookie banner; Plausible loads only after consent; Global Privacy Control respected |
| Sessions and passwords | httpOnly, Secure, SameSite=Lax session cookie; bcrypt passwords; sign out of all devices |
| Email verification | Server tokens, 24 hours, single use; SES sends the verification email |
| Password reset | Server tokens, 60 minutes, single use, older links cancelled, same message for every email (no enumeration); Google-only accounts get the sign-in email |
| Checkout start | Server creates Stripe Checkout from the signed-in identity; country gating on the server; monthly and annual prices |
| Stripe webhook safety | Signature checked; each event processed once |
| Shops API | Add, rename and remove shops on the server; sign-in required |
| Team invites API | Invites saved on the server; sign-in required |
| Founding counter | Served by the server (`/api/founding`) |
| Suggest a feature / Contact routes | Server routes exist; suggestions need sign-in |
| Legal pages | Five legal pages at /legal/*, linked, showing Version 20 / 20.1 |

---

## Decision summary

| ID | Decision | Replaces |
| --- | --- | --- |
| K59 | Brand is **Margins365**, one word, everywhere | K58 spelling |
| K60 | Header: Home / Sample shop / Pricing. “Sample report” is renamed “Sample shop” everywhere | — |
| K61 | Home “Start here” green area keeps three buttons; Compare plans | — |

| ID | Decision | Replaces |
|---|---|---|
| | and Sample shop swap places | |
| K62 | Every navigation opens at the top of the page | — |
| K63 | Real URL routes: refresh keeps the page; deep links and back/forward work | — |
| K64 | Footer: copyright line; old sentence removed; Help and Legal columns | 7 Nov footer handoff |
| K65 | New Help centre page with the Hard limits & billing FAQ and a Contact us form | 7 Nov form rules |
| K66 | Sample shop page buttons: new text; second button becomes a shop icon | K55 button text |
| K67 | Signed-in header: no trial CTA, business-name account button and menu, Info and Control room | 15.4 signed-in rules |
| K68 | Shops/multi-shop and seats/multi-seat fully built | OD5, Q22, Q23 defaults |
| K69 | The trial gives the tier the customer chose | K52 reverse trial |
| K70 | Professional account profile (Info) | 5 “Profile & sign-in” |
| K71 | Optional cancellation reason in the cancel flow | — |
| K72 | Founding offer: 50% off for 6 months for the first 100 paying users | K42 (in part) |
| K73 | Move fully to margins365.com; remove every marginos.online reference | K58 cutover wording |
| K74 | Legal documents published on the site (approved v20 texts) | 7 Nov “sign in to view” idea |
| K75 | SEO and discoverability for the public site (`Margins365-SEO-v20`) | Single-shell HTML, one title for every page |
| K76 | Free public calculators (Etsy UK, Amazon UK, Shopify UK, ecommerce margin), sharing the product's calculation module | — |
| K77 | Keyword landing pages and help articles (no competitor comparison | — |

| ID | Decision | Replaces |
|---|---|---|
| | page) | |
| K78 | Home H1 “Know your true profit and where it leaks” | “Stop guessing your e-commerce unit economics.” |
| K79 | Consent-gated Plausible analytics; consent banner; Cookie notice, Privacy Policy and DPA page v20.1 | K74 “essential only, no banner” |
| K80 | Every pop-up works on a phone (fits the visible screen, scrolls inside, buttons always reachable, page behind locked); site-wide mobile check | — |
| K81 | Remove the "14 days free. Cancel before day 14 and pay nothing. From £39/mo" banner everywhere | K43 banner |
| K82 | Every page opens at the top instantly, with no animated scroll (fixes K62 on iPhone) | — |
| K83 | Suggest a feature is emailed to info.marginos@gmail.com (and stored) | Q33 store-only default (S58) |
| K84 | Contact us reaches info.marginos@gmail.com signed in and out; visitor gets a confirmation without the message text (*needs Akthar's OK*); in-page pop-up; spam limits | 23.11 "copy of what they wrote" |
| K85 | Forgot password works end to end; no browser-only fallbacks; reset link built on the server | — |
| K86 | SES email set up and proven before release (verified domain, DKIM, MAIL FROM, production access, SPF, DMARC) | — |
| K87 | Hard limits & billing FAQ on **both** Pricing and the Help centre from one source; grouped accordion; Suggest a feature and Contact us links; “View sample report” → “Open Sample Shop” | K65 “move” |
| K88 | Contact pop-up, line under Send, intro and email: “Thank you for contacting us, we aim to respond within 24 hours.” | “can't promise a reply time” (part of K41) |

| ID | Decision | Replaces |
|---|---|---|
| K89 | Cancellation cancels in Stripe and is checked (no upcoming invoice); pop-up, SES email, server-backed status, Resubscribe, failure pop-up, audit log | Browser-only cancel (defect) |
| K90 | Trial-start confirmation email (SES, only after the server confirms the trial) and pop-up | Nothing sent today (defect) |

### What the live site does today (checked 11 November 2026, live bundle)

- Brand shows “Margins 365” (with a space). No “Margins365” string.
- No page routing: refresh always returns to Home; pages don't scroll to the top on change.
- “Help centre” in the footer is text, not a link. No Help centre page and no contact form.
- The footer still shows “Margins 365. Plans from £39/month including VAT after trial. Cancel in Plan & billing — there is no email cancellation route.” There is no copyright line.
- No screen to add or switch shops and no invite flow. Tier limits for shops and seats exist only as configuration.
- A profile with name, business name and phone (all required) exists.
- Account and product state is kept in the browser (localStorage `marginos.*`). See finding F1 in spec 23.13.
- No analytics, advertising or tracking scripts found. Essential cookies: the httpOnly session cookie (`marginos_session`, 30 days) and Cloudflare’s `__cf_bm` security cookie (30 minutes).

---

# Part A — Decisions K59–K74

### K59 — Brand: Margins365, one word

**Requirement.** `PRODUCT_NAME` = **Margins365** (one word, capital M, no space). Every interface string, page title, meta tag, PDF, email (subject, body, From name), legal document, Stripe product name and Google consent screen uses it. “Margins 365” (with a space), MarginOS and MarginSeam do not appear in customer-facing text. Code identifiers (CSS `--mo-*`, cookie and storage key names, file names) may stay. **Acceptance.** A text search of the built site, emails, PDFs and legal pages finds no “Margins 365”, “MarginOS” or “MarginSeam”. Page titles read “Margins365 — …”. **v19 sections affected.** Front matter, 2, 5.1, 6, 11, 12.9, 15.4, 17.3, 17.7, 20.4–20.5, 22, S73, K58.

### K60 — Header navigation and the Sample shop rename

**Requirement.** The public header has three navigation buttons: **Home**, **Sample shop**, **Pricing**, plus Sign in and the primary action (23.1). The public page formerly called “Sample report” is now **Sample**

**shop** at `/sample-shop`, with its heading “What a Margins365 diagnosis looks like” kept. Every link, button, heading, FAQ answer, email and document that said “Sample report” now says “Sample shop”. `/sample-report` redirects permanently to `/sample-shop`. **Acceptance.** Header shows exactly Home, Sample shop, Pricing in that order on every public page and device. No “Sample report” text remains. The old address redirects. **v19 sections affected.** 3.2, 7, 10.1, 15.2, 15.4, 17.5, 17.7, S31, S52, S61.

## K61 — Home “Start here” area

**Requirement.** The green area at the bottom of Home is titled **Start here** and keeps three buttons. Swap the positions of **Compare plans** and **Sample shop**; the third button stays where it is. Signed out, the trial button keeps the label “Start 14-day free trial”. Signed in on a trial or paid plan it becomes **Go to Control room** (K67). **Acceptance.** Title “Start here”; three buttons; Sample shop and Compare plans have swapped; each opens its page at the top. **v19 sections affected.** 15.4, 17.7.

## K62 — Open every page at the top

**Requirement.** Any click that opens a different page (header, footer, buttons, links in FAQ, emails landing on the site) shows the new page from the top. In-page anchors (for example “Compare plans” to the comparison table on Pricing) scroll to their target. Back/forward restore the previous position. **Acceptance.** From the bottom of every page, every link to another page lands at the top, on phone, iPad and desktop. **v19 sections affected.** 15.1, 15.2.

## K63 — Real routes; refresh keeps the page

**Requirement.** Every public and signed-in screen has its own address (route map in 23.1). Refresh reloads the same screen and, signed in, the same shop. Deep links work signed out (public pages) and signed in (after sign-in, the user returns to the requested page). Back and forward work. Each page has its own title and canonical URL on margins365.com. Unknown addresses show a 404 page. **Acceptance.** Refresh on every route stays on that route. Pasting a signed-in link while signed out asks for sign-in, then opens that link. Back/forward move through visited pages. **v19 sections affected.** 10.1 #3, 11, 15.1.

## K64 — Footer

**Requirement.** On every page:

- Copyright: **© 2026 Margins365. All rights reserved.** The year updates automatically each year.
- Remove in full, with no replacement: “Margins 365. Plans from £39/month including VAT after trial. Cancel in Plan & billing — there is no email cancellation route.”
- **Help** column: Help centre, Sign in (signed out) or Control room (signed in).
- **Legal** column: Terms, Privacy, Refunds & cancellation, DPA & subprocessors, Cookies. Each

opens the published document in a new tab (K74).
- No Contact link (the form is in the Help centre). **Acceptance.** Exact copyright text; the old sentence is absent; every footer link works; legal links open in a new tab at the top of the document. **v19 sections affected.** 10.1, 15.4; replaces the 7 November footer handoff.

## K65 — Help centre and Contact us form

**Requirement.** New public page `/help`, reachable from the footer and the account menu. The **Hard limits & billing** FAQ appears here **and stays on Pricing** (K87 supersedes the original move; one content source). The Contact us form has **Name, Phone number, Business name, Email, Country, Message**. Submissions go to **info.marginos@gmail.com**, a pop-up confirms success, and a copy is emailed to the visitor's address through SES. Full behaviour, validation, limits and spam protection: spec 23.11. **Acceptance.** HC-1 to HC-6 in spec 23.11. **v19 sections affected.** 3.2, 10.1, 15.4, Q33; replaces section 1 of the 7 November handoff (fields, notification and reply rules).

## K66 — Sample shop page buttons

**Requirement.**

- **First button** (opening section, green): signed out **Start your own shop** → starts the 14-day trial journey (sign-up, then Choose a plan); signed in without a plan **Choose a plan**; signed in on a trial or paid plan **Go to Control room**.
- **Second button** (bottom of the first dashboard section): a **shop icon** button, at least 44 × 44 px, with the accessible name and tooltip **Open Sample Shop**. It opens the sample shop's Control room (`/app/sample`); signed out it asks the visitor to sign in or create an account first, then opens it.
- The header keeps “Start 14-day free trial” for signed-out visitors. **Why these words.** On a page now called “Sample shop”, two buttons both reading “Open Sample Shop” no longer say anything different from the page itself. “Start your own shop” says the next step after looking at an example: make your own. It is a secondary button, so it does not compete with the one primary label (K46). Signed-in users already have a shop, so for them the useful next step is their Control room. The icon keeps the second action compact while the accessible name keeps it clear for screen readers. **Acceptance.** Button text changes with sign-in state as above. The icon button has the accessible name “Open Sample Shop” and opens the sample Control room. **v19 sections affected.** 15.4, 17.7, S52, S61; replaces the K55 button text.

## K67 — Signed-in header, account menu and Control room

**Requirement.** Spec 23.1. In short: signed-in users on a trial or paid plan never see “Start 14-day free trial”. The green top-right button shows the **business name** and opens the account menu. On Scale (trial or paid) the menu includes the **shop switcher**. The menu includes **Info** and **Control room**. The signed-in identity shows the business name, not the email. The Control room is one click from every signed-in page. **Acceptance.** IA-1 to IA-6 in spec 23.1. **v19 sections affected.** 5, 10.1, 15.4, 22.

## K68 — Shops, multi-shop, seats and multi-seat

**Requirement.** Spec 23.2 (shops) and 23.3 (seats, roles, invites). Shops 1/1/1/3; seats 1/1/2/5; order limit account-wide on every plan; data separated per shop; owner-only billing, cancel, shops and team. **Acceptance.** SH-1 to SH-7 and ST-1 to ST-7. **v19 sections affected.** Open decisions (OD5, Q22, Q23 now decided), 3, 6, 8, 12.7, 17.3. Live today: not built.

## K69 — The trial gives the chosen tier

**Requirement.** A Starter trial gives Starter, Growth gives Growth, Pro gives Pro, Scale gives Scale, each with its own order limit. This replaces the K52 reverse trial: no Pro-for-everyone trial, no Keep Pro, no “Every trial includes Pro features”, no lock-on-conversion. Changing plan during the trial is allowed (same end date, no new trial, no charge today). Checkout lead for every plan: “Your 14-day free trial of [Plan] starts today. We'll ask for a card now so your plan can continue after the trial. You pay nothing today. Unless you cancel, we will automatically charge £[amount] including VAT on [date] for your [monthly or annual] [Plan] plan. Cancel any time before [date] in Plan & billing — it takes one click. We'll email you a reminder before you're charged.” Full lifecycle: spec 23.9. **Acceptance.** TR-1 to TR-5. S17, S36–S46, L17 and D13 are replaced as listed in spec 12.11. **v19 sections affected.** 3, 3.1, 3.2, 6, 7, 10.1, 12.4A, 12.5, 12.5A, 12.5B, 12.10, 12.11, 12.12, 16.4, 16.5, 22.10.

## K70 — Account profile (Info)

**Requirement.** Spec 23.4. Sign-up stays short; Info collects name, business name, country, email (required) and phone, business address, VAT number, website (optional), with currency and time zone. Phone becomes optional. **Acceptance.** IN-1 to IN-6. **v19 sections affected.** 5.

## K71 — Cancellation reason

**Requirement.** Spec 23.10. Optional reason picker and free text on the single cancel confirmation screen. Never required, never a second step, never delays Confirm cancel. Stored for reporting; unlinked from the account at access end. **Acceptance.** CA-1 to CA-4. **v19 sections affected.** 12.5A.

## K72 — Founding offer: 50% off for 6 months, first 100 paying users

**Requirement.**

- The first **100 paying accounts** get **50% off their first 6 monthly payments**. From payment 7 the normal price applies.
- Founding monthly prices: **Starter £19.50, Growth £39.50, Pro £64.50, Scale £99.50** a month including VAT for 6 months, then £39 / £79 / £129 / £199.
- Annual plans: the same value is given as **25% off the first year** (half price for 6 of the 12 months): **£292.50, £592.50, £967.50, £1,492.50** for the first year, then £390 / £790 / £1,290 / £1,990. (Product decision: annual payments are yearly, so “6 months at half price”

becomes 25% off the first annual payment.)

- **Counting.** A place is **reserved** when a trial starts through Checkout and **confirmed** when the first payment succeeds. A reservation is released if the trial is cancelled, the first payment finally fails or the first payment is refunded. Reserved + confirmed never exceeds 100. One place per account. The counter lives on the server.
- **Plan changes** during the 6 months keep 50% off the new plan until the 6 months end. Cancelling ends the offer; a later account does not get it again.
- **Honest display.** While places remain, Pricing and Checkout say: “Founding offer: 50% off your first 6 months — for the first 100 paying customers. [n] places left.” The number is the real server count. When it reaches zero the offer disappears everywhere automatically. No countdown timers, no invented scarcity, no reset.
- **Disclosures.** Checkout, the trial-started email, Plan & billing and the reminder show the founding amount, how many payments it lasts, the date the normal price starts and the normal amount. A “Founding price ends soon” email goes 14 days before the 6th month ends.
- **Stripe.** A 50% coupon lasting 6 monthly invoices for monthly plans; a 25% one-off coupon for annual plans; applied server-side only when a place is reserved. **Acceptance.** FO-1 Only 100 places can ever be confirmed, even with simultaneous Checkouts. FO-2 Payments 1–6 charge the founding amount; payment 7 the normal price. FO-3 Annual first year charges 75% of the annual price. FO-4 Released places return to the counter. FO-5 The displayed count equals the server count; the offer vanishes at zero. FO-6 All disclosures show founding amount, duration and normal price. FO-7 The ends-soon email is sent. **v19 sections affected.** 2, 3, 3.1, 3.2, 7, 10.1 #11, 12.5, 12.10, 12.11 (S3, S24), 16.4, 16.5, 22.12 #8; K42 is superseded for the new offer only (the old 25% offer stays removed).

## K73 — Move fully to margins365.com

**Requirement.** margins365.com is the only domain. Remove every reference to marginos.online: links, canonical and Open Graph URLs, sitemap, emails (From, links, reply-to), Google OAuth origins and redirect URIs, Stripe success/cancel/portal/webhook URLs, SES sending identity, environment examples and documents. SES sends from a verified margins365.com identity with SPF, DKIM and DMARC passing (the 11 November check found the apex SPF and the SES domain verification still missing). Ask Stripe/Link to update the statement descriptor from “MARGINOS” to Margins365. **When marginos.online is cancelled, its redirect to margins365.com stops**, so old bookmarks, old emails and any link still pointing there will break; that is why every reference must be gone first. **Acceptance.** Text search of code, built site, emails and consoles finds no marginos.online. Test mail passes SPF/DKIM/DMARC. Google sign-in and Stripe returns work on margins365.com only. **v19 sections affected.** Front matter, OD3, 11, 16.5, 20.3–20.5, 22, S74, S75.

## K74 — Legal documents on the site

**Requirement.**

- Publish the approved v20 texts: **Terms**, **Privacy Policy**, **Refunds & cancellation**, **DPA & subprocessors**, **Cookie notice**, at the `/legal/...` routes in 23.1, as web pages with a

**Download PDF** link. Each shows its version (v20) and effective date.

- **Public:** readable without signing in (UK GDPR requires privacy information before data is collected; Terms must be available before purchase).
- **Linked from:** the footer Legal column, the sign-up screen, Stripe Checkout (terms and refund links in the Checkout page settings) and the Help centre. These links open in a new tab.
- **Consent:** sign-up shows “By creating an account you agree to the Terms and have read the Privacy Policy.” Checkout shows the Terms and Refunds & cancellation links. Store per account: document, version, time accepted. A material change to the Terms shows the new version at next sign-in for acceptance.
- The trading name in the documents is Margins365. Registered address, company number and ICO number to be added before launch if required (UK Companies Act trading disclosures).
- **Cookies:** the live site sets two essential cookies: `marginos_session` (30 days) and Cloudflare’s `__cf_bm` security cookie (30 minutes), and uses localStorage. No analytics or tracking was found, so the Cookie notice states essential-only (and lists Cloudflare) and there is no banner. Development confirms nothing non-essential is added; if anything is, a consent banner is needed first. Cloudflare is listed as a subprocessor in the DPA. **Updated by K79:** analytics (Plausible, cookieless) is added behind a consent banner, and the Cookie notice, Privacy Policy and DPA page move to v20.1. **Acceptance.** LG-1 Every document loads signed out, on every device, at its route and as a PDF. LG-2 Footer, sign-up, Checkout and Help centre links open the right document in a new tab. LG-3 Version and effective date shown. LG-4 Acceptance stored. LG-5 No placeholder text is published. **v19 sections affected.** 10.1 #3, 12.6, 15.4, 16.4, 20.4.

## K75 — SEO and discoverability

**Status. Approved by Akthar, 11 November 2026, 14:38 Europe/London.** Full requirements: **`/workspace/v20.1/Margins365-SEO-v20.1.md`** (and `.pdf`). **Why.** The 11 November audit found the site is not search-ready: every address returns the same empty HTML shell with one title (“Margins 365 — margin leak diagnosis”), there are no `<a href>` links, robots.txt, sitemap.xml and unknown paths return Home with status 200, there is no canonical, Open Graph, structured data or manifest, www and non-www both serve the site, and mobile LCP is 2.9 s (target < 2.5 s). **Requirement (SEO spec Parts A–C).** Prerendered/server-rendered HTML for public pages (Home, Sample shop, Pricing, Help centre, five legal pages, 404); signed-in app `noindex`; the exact titles, meta descriptions, H1s, canonicals and robots in SEO spec 5.1; real `<a href>` navigation; robots.txt and XML sitemap; real 404 status; 301s to `https://margins365.com` (http, www, trailing slash, `/sample-report`, marginos.online path-preserving until cancelled) and HSTS; Open Graph/Twitter tags with a 1200 × 630 image; favicon set and web manifest; JSON-LD (Organization, WebSite, SoftwareApplication with GBP offers, FAQPage, BreadcrumbList; no invented ratings); `lang="en-GB"` and self-referencing hreflang; Core Web Vitals LCP < 2.5 s, INP < 200 ms, CLS < 0.1; asset caching; Search Console and Bing verified by DNS with the sitemap submitted. No analytics or other non-essential cookies without the Cookie notice update and consent where required. **Related.** The calculators, landing pages and help articles, Home H1 and analytics are K76–K79 below. **The competitor comparison page was not approved and has been removed. Acceptance.** QA suite **SEO** (SEO-01 to SEO-32) in the QA Prompt v20. **v19 sections affected.** 15 (performance and accessibility), 22 (brand assets: OG image, favicons); v20

23.1 (route map).

## K76 — Free public profit calculators

**Status.** Approved by Akthar, 11 November 2026, 14:38 Europe/London. **Build after the core v20 QA pass. Requirement.** Four public, no-sign-up calculators: `/etsy-profit-calculator-uk`, `/amazon-fee-calculator-uk`, `/shopify-profit-calculator`, `/ecommerce-profit-margin-calculator`. They **must call the product's own calculation module and fee/tax configuration** (12.0, 12.2, 12.3 rounding and target/break-even price, 12.7 validation, 16.2 presets with "last checked" dates, 16.3 VAT rates, ECB rates). Outputs: revenue, every fee line, return cost, contribution margin, true profit per order, net margin, verdict, break-even ROAS/ACOS, break-even and target price, optional monthly totals, Show the maths. Calculation runs in the browser; **entered values never leave the browser** or reach analytics. Inputs, outputs, behaviour and golden examples: spec 23.15. **Acceptance.** PC-1 to PC-6 (spec 23.15); QA suite **PCALC**. The golden examples were computed with the spec formulas (`/workspace/v20/src/calc_examples_v20.py`).

## K77 — Keyword landing pages and help articles

**Status.** Approved by Akthar, 11 November 2026, 14:38 Europe/London. **Publish after the core v20 QA pass. Requirement.** `/profit-leak-checklist` and `/multi-channel-profit`, then the 10 help articles in SEO spec 15.2 under `/help/<topic>` at about 2 a month. Metadata from SEO spec 15.1, prerendered, in the sitemap, every fee/tax/product fact sourced and dated, tax content marked "not tax advice" and the VAT article checked by the accountant. **No competitor comparison page.** Spec 23.16. **Acceptance.** LP-1 to LP-3; QA SEO-34 to SEO-36.

## K78 — Home H1

**Status.** Approved by Akthar, 11 November 2026, 14:38 Europe/London. **Requirement.** Home's only H1 reads **“Know your true profit and where it leaks”**, replacing “Stop guessing your e-commerce unit economics.”. The supporting sentence and the Product section headline (K55) stay. Spec 23.17. **Acceptance.** H1-1; QA SEO-33.

## K79 — Consent-gated analytics and the consent banner

**Status.** Approved by Akthar, 11 November 2026, 14:38 Europe/London. **Requirement. Plausible Analytics** (EU-hosted, cookieless, no stored IP addresses) on public pages only, loaded **only after "Accept analytics"**. Banner with equal **Accept analytics** and **Reject**, no pre-ticks, close = reject, Global Privacy Control = reject, choice stored as `m365_consent` for 12 months or until the notice changes, **Cookie settings** in the footer Legal column to change it. No analytics in the signed-in app, sign-in/reset pages or emails; events carry no personal data and no entered values. Publish the **v20.1** Cookie notice, Privacy Policy and DPA & subprocessors page in the same release. Spec 23.18. **Acceptance.** AN-1 to AN-6; QA suites **CONS** and **ANL**.

# Part A (continued) — Decisions K80–K86: Akthar's iPhone test, 11 November 2026

**Status.** K80, K81, K82, K83 and K85 are fixes **Akthar asked for on 11 November 2026** after testing the live site on his iPhone. K84 and K86 are what it takes for his contact-form and email requests to work. **One item needs Akthar's OK before it's built:** within K84, the visitor gets a **confirmation without their message text**. That's a Business & Product security recommendation. Two small legal-wording follow-ups (K83, K84) also need his approval before the next legal version. Full requirements and acceptance criteria are in spec **23.19** (reproduced as B.19 below).

### Live findings behind K80–K86 (checked 11 November 2026, 17:30 Europe/London)

Checked on the live site (bundle `index-DrtqBa1f.js`), with safe API probes (no real messages sent, no accounts created), DNS lookups, a phone-sized browser test (390 × 664) and the server code snapshot from 11 November 13:38.

| # | Issue | What happens now (evidence) | Root cause | Broken live? |
|---|---|---|---|---|
| 1 | Free-trial pop-up can't scroll | At 390 × 664 the plans pop-up is **1,541 px tall**. Its top (Close button and the Starter to Pro tiles) sits **893 px above the screen**. Swiping scrolls the page behind it, not the pop-up. On iPhone Safari the bottom, with the **Start 14-day free trial** button, falls behind the browser toolbar, as in Akthar's screenshot. | Every pop-up uses one of two shared containers. Both are pinned to the full screen with **no maximum height and no scrolling inside**. The page behind isn't locked. The cookie banner sits on a **higher layer than pop-ups**, so on a first visit it can cover a pop-up's buttons. | **Yes.** Same fault in sign-in / sign-up / profile / reset, plans & trial, Clear sample data, Delete my shop data, and Cancel trial / subscription (which also holds the reason list) |
| 2 | Banner | Exact text: **"14 days free. Cancel before day 14 and pay nothing. From £39/mo"**. It's one component at the top of the public site frame, sticky with the header, so it shows on **every public page** (Home, Sample shop, Pricing, Help centre, legal pages), signed in or out. Dismissing it | The K43 banner is still built in. | Present on every public page |

| # | Issue | What happens now (evidence) | Root cause | Broken live? |
|---|---|---|---|---|
| | | lasts only for that browser session. Header and banner together take **199 px of a 664 px phone screen**. | | |
| 3 | Pages open at the bottom | A page change now updates the address and asks the browser to go to the top. But the stylesheet turns on **smooth scrolling for the whole page**, so the jump becomes an animation of about 1 second that starts from the old position. Trace from the bottom of Home: the new page starts at y ≈ 1,900–6,000 and animates upwards. iPhone Safari stops that animation when the new page changes height or when the user touches the screen, which leaves them at or near the bottom. With smooth scrolling switched off, the same clicks land at the top instantly. | Smooth scrolling applied to page changes, and the scroll fires before the new page has rendered. | **Yes on iPhone** (Akthar saw it; the animation was reproduced in a phone emulator) |
| 4 | Suggest a feature | Signed in only. The text goes to the server (`/api/feature-suggestions`), which **saves it in the database** and replies "saved for review". **No email is sent** (server code). Signed out, the server replies 401 "Sign in first". | Built to the old Q33 default (store only). | **Not sent to info.marginos@gmail.com** |
| 5 | Contact us | The same Help centre form is used signed in and signed out (signed in, the fields are pre-filled). It posts name, phone, business name, email, country and message to `/api/contact`. The page doesn't send the recipient, which is right, but it doesn't include the account details either. There's **no honeypot and no minimum fill time**. Success shows the **browser's own alert box**. The limit is 4,000 characters against the spec's 5,000. Validation works (empty fields and an over-long message are refused with 400). Who the server sends to **couldn't be confirmed without sending a real message**, so that wasn't done. | Delivery depends on the SES setup (row 7). | **Delivery unproven** |

| # | Issue | What happens now (evidence) | Root cause | Broken live? |
|---|---|---|---|---|
| 6 | Forgot password | The request works: a made-up @example.com address gets the neutral 200 response, a bad address gets 400, and a bad reset token gets 400 "invalid or expired". **But:** (a) if the server fails, for example because SES refuses the email (HTTP 502), the page **quietly switches to a built-in demo routine** that keeps a fake token in the browser and still says "If an account exists, we've sent a reset link." The user is told it worked when no email went out. (b) The server builds the reset link from an **"origin" value the browser sends** (server code). Anyone could ask for a reset for someone else's email with their own website as the origin, so the real reset email would carry a link to their site (**password-reset link poisoning, P0 security**; Development to confirm against current code). (c) `/reset-password` returns **404**; the link uses `/?reset=`. (d) Email sign-in and Google sign-in also fall back to a **browser-only "signed in"** state on network errors. (e) Server email text still says “Margins 365” and invites replies to an address that has no inbox. | Demo fallbacks left in the production build; the server trusts a browser-supplied origin; SES status unknown. | **Partly working, not proven end to end** |
| 7 | Email (SES) setup | DNS (17:30): `mail.margins365.com` has MX `feedback-smtp.eu-north-1.amazonses.com` and SPF `include:amazonses.com`. That means a custom MAIL FROM is configured, so a margins365.com identity exists in SES eu-north-1. `_dmarc` is `v=DMARC1; p=none;` with no reporting address. The apex has **no SPF and no MX**. `_amazonses` TXT is absent. `/api/health` reports `sesConfigured: true`, region eu-north-1. **Correction to the earlier note:** `_amazonses` is the old verification method. SES now verifies a domain with 3 DKIM CNAME records whose names are random and can't be listed from outside, so their absence **doesn't prove** | Can't be confirmed from outside. | **Unknown. Development must check the SES console (K86)** |

| # | Issue | What happens now (evidence) | Root cause | Broken live? |
|---|---|---|---|---|
| | | the domain is unverified. **Sandbox status can't be seen from outside either.** If SES is still in the sandbox, it only delivers to verified addresses: the notification to info.marginos@gmail.com could arrive while every reset email, verification email and visitor confirmation to a real customer fails. | | |

**Also found (existing rules; no new decision needed):**

- **D-1 (P0) Founding prices are rounded to whole pounds** in the plans pop-up: £19.50 shows as £20, £39.50 as £40, £64.50 as £65 and £99.50 as £100. The annual founding prices are rounded the same way. Akthar's screenshot shows "£100/month" and "we will automatically charge £40". The trial disclosure therefore states a charge of **£40 when the real charge is £39.50**. This breaks K72 / 12.5C and the pre-contract disclosure (12.5A). Show pence wherever a price isn't a whole pound.
- **D-2** The cookie banner sits above pop-ups and has no bottom safe-area padding (K80 fixes it).
- **D-3** The viewport tag has no `viewport-fit=cover`, so the site's safe-area padding does nothing today. That's harmless now, but it matters once anything is pinned to the bottom (K80).

## K80 — Every pop-up works on a phone, plus a site-wide mobile check

**Requirement.** Every pop-up, sheet, drawer and confirmation (sign-in and reset, plans and trial, Clear sample data, Delete my shop data, Cancel with reason, contact success, account menu, shop switcher, team, phone menu, cookie banner) must:

- fit the **visible** screen, on iPhone Safari with the address bar shown or hidden and with the keyboard open;
- scroll inside, with the title and Close always visible;
- keep its buttons reachable (never behind the browser toolbar, home indicator or cookie banner), with safe-area spacing at the bottom;
- lock the page behind it and restore the position on close;
- sit above every other layer;
- trap focus and return it on close.

A site-wide mobile check runs on every page and screen at 320–430 px, on iPad, iPhone Safari, Android Chrome and Samsung Internet. Spec 23.19.1. **Acceptance.** MOB-1 to MOB-6; QA suite **MOB**.

## K81 — Remove the "14 days free" banner

**Requirement.** Remove the sticky banner **"14 days free. Cancel before day 14 and pay nothing.**

**From £39/mo"** from every page and device, signed in and out, together with its dismiss button and saved setting. There's no replacement. This supersedes the K43 banner. The trial terms on Pricing, in the plans pop-up, at Checkout and in Plan & billing stay. Spec 23.19.2. **Acceptance.** BN-1 to BN-3; QA MOB-12, PUB-15 (rewritten).

## K82 — Every page opens at the top, instantly

**Requirement.** Every change of page lands at the very top **with no animated scroll**, from any entry point, on every device. The cause on the live site is smooth scrolling applied to the whole page. Smooth scrolling is allowed only for in-page jumps. Late-loading content must not push the page down. Back and forward may restore the earlier position. This fixes K62 on iPhone. Spec 23.19.3. **Acceptance.** NV-1 to NV-4; QA NAV-33 to NAV-36.

## K83 — Suggest a feature is emailed to info.marginos@gmail.com

**Requirement.** Suggest a feature stays signed in only. The server stores each suggestion, then emails it through SES to **info.marginos@gmail.com**. The email has the account email, business name, plan and status, role, number of shops and the time, with Reply-To set to the submitter. The success message is shown in the page. If sending fails, the server alerts and retries. Limits: 5 per hour and 20 per day per account. The FAQ wording is updated. This replaces the Q33 store-only default (S58). Spec 23.19.4. **Acceptance.** FS-1 to FS-5; QA HELP-17 to HELP-19.

## K84 — Contact us reaches info.marginos@gmail.com, signed in and signed out

**Requirement.**

- One form and one server route. The server always sends to **info.marginos@gmail.com**; the page never chooses the recipient. Reply-To is the visitor.
- Signed-in sends add the account context from the session.
- The visitor gets a **confirmation without their message text**. *(Needs Akthar's OK.)*
- The success pop-up is shown in the page, not the browser alert box, and only after the message is stored.
- Failures: alert and retry.
- Spam protection: a honeypot, a 3-second minimum fill time, 5 per IP and 3 per email per hour in shared storage, the real client IP, and header-injection checks.
- Message length 10–5,000 characters.

Spec 23.19.5 (adds to 23.11). **Acceptance.** HC-7 to HC-12; QA HELP-20 to HELP-24 (HELP-06 and HELP-08 updated).

## K85 — Forgot password works end to end

**Requirement.**

- No browser-only fallback for any account action. Server errors show a clear "couldn't reach Margins365" message.
- The reset link is built on the server from `https://margins365.com` only, never from a browser-supplied origin. This closes a reset-link poisoning risk.
- The link opens a real `/reset-password` page, which is 404 today.
- SES failures alert and retry while the user still sees the neutral message.
- The K57 / Q34 limits and expiry are unchanged.
- Emails use "Margins365" and don't invite replies.

Spec 23.19.6. **Acceptance.** PR-1 to PR-6; QA AUTH-21 to AUTH-25.

## K86 — Email sending set up and proven before release

**Requirement.**

- The SES eu-north-1 margins365.com identity is **Verified**, with Easy DKIM and MAIL FROM **Successful**.
- **Production access** (out of the sandbox).
- Bounce and complaint handling.
- An apex SPF record, and DMARC reporting moving later to quarantine.
- From is on margins365.com, with Reply-To set on every email (the domain has no inbox).
- Before QA, each email is proven to pass SPF, DKIM and DMARC at Gmail, Outlook and iCloud, and to reach an unverified external address.

This blocks release of K83–K85 and every email. Spec 23.19.7. **Acceptance.** ES-1 to ES-5; QA EML-22 to EML-25.

**D-1 (defect against K72, P0).** Founding prices must show pence: £19.50, £39.50, £64.50, £99.50, £292.50, £592.50, £967.50, £1,492.50, in the plans pop-up, on cards, at Checkout, in Plan & billing and in emails. The trial disclosure must state the exact amount that will be charged. QA OFF-17.

## K87 — The FAQ stays on Pricing and is copied to the Help centre, from one source

**Status.** Requested by Akthar, 11 November 2026 (“Copy all these questions to Help center”). This supersedes the K65 “move”.

**Requirement.**

- **Same FAQ in both places.** The Hard limits & billing FAQ (spec 3.2, 15 entries: the 14 on the live Pricing page plus the approved founding-offer question) shows **in full on Pricing and in the Help centre**.
- **One content source** feeds both pages, their prerendered HTML and their FAQPage JSON-LD, so the two can't drift apart.
- **Help centre layout:**
- five group headings with an accordion;

- a link to Suggest a feature from Q3 (signed out: sign in first);
- a Contact us link to the form;
- anchors for each answer;
- links to other pages open at the top (K82).
- **No duplicates.** The four overlapping Help-only questions on the live site are retired and folded in. The two Help-only sign-in and password answers stay.
- **Button rename.** The button under the Pricing FAQ, “View sample report”, becomes **“Open Sample Shop”** (K60, K66). No trial button is shown to trial or paid users (K67), and there's no Sign in or Account button when signed in.
- **Answers corrected.** The live answers are reconciled with K60, K69, K72 (pence and annual), K81, K83 and K36.

Spec 3.2 and 23.20.

**Acceptance.** FQ-1 to FQ-6; QA HELP-25 to HELP-32.

## K88 — Contact us message: “Thank you for contacting us, we aim to respond within 24 hours.”

**Status.** Requested by Akthar, 11 November 2026, word for word. It reverses the part of K41 that removed all published response times. It is an aim, not a guarantee, and not a plan feature.

**Requirement.**

- **Pop-up:** title “Message sent”; body exactly “Thank you for contacting us, we aim to respond within 24 hours.”
- **Line under the Send button** after success: the same sentence.
- **Form intro:** “We read every message and aim to respond within 24 hours. Do not use this form to cancel.”
- **Visitor confirmation email:** “Hi [Name], Thank you for contacting us, we aim to respond within 24 hours. You sent your message from the Margins365 Help centre on [date, time, time zone].” Still no message text (K84).
- **Remove everywhere:** “we can’t promise a reply time” and “We don’t promise a reply time”.
- **No change** to the Terms, Refunds, DPA or Cookie Notice (they have no reply-time line), or to the Privacy Policy's one-month data-rights reply. Suggest a feature keeps “We can’t promise a reply” (feature ideas, not the contact form).
- Comparison table and pricing still show no support target (K41).

Spec 23.21.1.

## K89 — Cancellation must cancel in Stripe, show a pop-up and send an email

**Status.** Requested by Akthar, 11 November 2026, after his test cancellation gave no pop-up and no email. **Defect found:** Confirm cancel only changes the browser. There is no server cancel route,

Stripe is never told, the trial stays **Trialing** and **the card would be charged at trial end**. No email exists. The success text is small grey text in the Profile & sign-in card, off screen. 12.5A already required all of this; it was not built.

**Requirement.**

- **Server route** (owner only): sets `cancel_at_period_end: true` in Stripe, with an idempotency key.
- **Check Stripe before success:** read the subscription back, and for trials confirm there is **no upcoming invoice**. Only then record it and answer success.
- **Failure:** pop-up “We couldn’t cancel your [trial/subscription]. Nothing has changed — you will still be charged on [date] unless you cancel. Please try again.” The browser never sets a cancelled state by itself.
- **Confirmation pop-up:** “Your trial is cancelled” / “Your subscription is cancelled”, the access-until date, “You won’t be charged” / “No further payments will be taken”, the deletion date, the reference, and “We’ve emailed a confirmation to [email]”.
- **SES email**, once: reference, plan, date cancelled, access until, no further charges, data deletion date, download link, how to resubscribe.
- **Plan & billing** shows the server state on every device: “Cancelled — access until [date]”, the reference, and a Stripe line (“cancels on [date], no upcoming invoice” or “cancelled”). **Resubscribe** replaces Cancel.
- **Resubscribe** before access ends sets `cancel_at_period_end: false`, keeps the same end date and gives no new trial.
- **Audit log** entry for every attempt.
- **Webhook sync** for cancels done in Stripe or Link. No “free” plan (G9).
- No trial reminder after a cancellation.

Spec 23.21.2. How Akthar checks today: 23.21.3.

## K90 — Trial-start confirmation email and pop-up

**Status.** Requested by Akthar, 11 November 2026 (“When someone starts or cancels a trial we need to send them an email confirmation.”). **Defect found:** no trial-start email exists; SES only sends email verification. On return from Checkout there is no confirmation. 12.5A, CHK-07 and EML-05 already required it.

**Requirement.**

- **Send only after the server confirms the trial** (webhook processed, Stripe shows `trialing` with `trial_end`, account saved). Once per subscription. Never on an abandoned, cancelled or failed Checkout.
- **Email (SES)** with: plan (monthly/annual), trial start and end, first charge date and amount including VAT to the penny, founding price for the first 6 monthly payments (or first year) then the full price, order limit, how to cancel (Plan & billing only, one click, replying does not cancel), the 3-day reminder, a reference and links to the accepted terms.
- **Pop-up** on return from Checkout, only after the server confirms: “Your 14-day free trial of

[Plan] has started”, with the same facts. If not confirmed within 30 seconds, a “still confirming — no charge has been taken” message instead.
- Amounts come from Stripe, not the template. Audit log entry.

Spec 23.21.4.

---

## Build order

1. K73 domain and K59 brand (configuration; unblocks emails and sign-in).
2. K63 routes and K62 scroll (every other change depends on addresses).
3. Server-side data store per shop (finding F1), then K68 shops and seats.
4. K70 Info and K67 account menu and identity.
5. K69 trial tier, then K72 founding offer (Stripe test mode).
6. K71 cancellation reason.
7. K60, K61, K66 navigation, Home and Sample shop page.
8. K64 footer, K65 Help centre and form (SES).
9. K74 legal pages, links and acceptance records.
10. K75 SEO and K78 Home H1: prerendering and head tags alongside K63 routes; robots.txt, sitemap, redirects, OG image, icons and JSON-LD; then speed and caching; Search Console and Bing last, on production.
11. K79 consent banner first, then Plausible analytics behind it, with the v20.1 Cookie notice, Privacy Policy and DPA page published in the same release.

**K80–K86 (Akthar's iPhone test), slotted into the order above:** K86 SES setup and production access go **with step 1** (every email depends on it). K82 scroll fix goes with step 2. K80 pop-ups, site-wide mobile check and K81 banner removal go with step 7. K85 forgot password goes with step 4. K83 and K84 go with step 8. Fix D-1 (pence in founding prices) goes with step 5. **K89** (server cancel, Stripe check, pop-up, email, status, audit) goes with step 6 and is a **release blocker**; K90 (trial-start email and pop-up) goes with step 5; K88 wording goes with step 8. **K87** (FAQ on Pricing and Help centre from one source, button rename) goes with step 8.

**Phase 2 (after the core v20 QA pass):**

12. K76 calculators on the shared calculation module; QA suite PCALC before they go live.
13. K77 landing pages, then help articles at about 2 a month; SEO checks per page.

## Hand to QA when

All of these are true:

- Every K59–K75, K78 and K79 item is built on a staging site at margins365.com (or a staging subdomain of it).
- Developers have run their own checks against each acceptance list and the spec 12.11 and

12.12 tables.
- Stripe test mode has all prices, trials and both founding coupons; SES sends from margins365.com and passes SPF/DKIM/DMARC.
- **v20.1:** every P0 and P1 gap GA-01–GA-66 is fixed, the release gate RG-1–RG-4 passes, and suite GAP and suite E2E are ready to run.
- K80–K90 and fix D-1 are built. For K90, a test trial sends one start email and a failed Checkout sends none. For K89, a Stripe test-mode cancellation shows “Cancels [date]” with no upcoming invoice, and a test-clock run past trial end shows no charge. The K86 proof is attached: SES console screenshots (identity Verified, DKIM and MAIL FROM Successful, production access) and passing headers for each email at Gmail, Outlook and iCloud.
- Registered address, company number and ICO number to be added before launch if required (UK Companies Act trading disclosures).

K76 and K77 (Phase 2) get their own QA pass (suites PCALC and SEO-34 to SEO-36) before they go live.

Then QA runs `/workspace/v20.1/Margins365-QA-Prompt-v20.1` and reports pass/fail with evidence. QA does not change code; failures go back to Development, then QA re-tests. Nothing goes to Marketing until QA passes.

---

## Part B — Product architecture (spec section 23, reproduced; B.n = spec 23.n)

**Approved by Akthar Uddin, 11 November 2026 (Europe/London).** Akthar asked for the product to be designed as a whole working product, not only a list of changes. Where his messages left gaps, the Business & Product Agent made the product decisions in this section under that instruction. These are requirements, not UI design: Design decides how screens look; this section fixes what the product does. Formulas in 12.0–12.3 are unchanged. K numbers refer to Appendix B.

### B.0 Shared rules for every area

- **Server is the source of truth.** Plan, entitlement, role, shop, seat, founding-offer and trial state come from the server. The browser never decides access. Product data (orders, costs, ads, scenarios, results) is stored server-side per shop. Browser storage holds only UI preferences and a non-sensitive cache that is cleared on sign-out and at account closure (see 23.13, finding F1).
- **Every screen has an address (K63).** Refresh, back, forward and shared links reopen the same screen. Every navigation opens at the top of the new page (K62). Going back restores the previous scroll position, which is normal browser behaviour.
- **Time.** Dates and times shown to customers use the account time zone and name it. Stored times are UTC.
- **Words.** The product name is `PRODUCT_NAME` = **Margins365** (K59). Plan names are Starter, Growth, Pro and Scale.
- **Accessibility and devices.** Everything in this section meets 15.1–15.5 (WCAG 2.2 AA, 44 px

targets, phone, iPad portrait and landscape, desktop).

- **Audit events.** Owner actions that change billing, shops, seats, roles or the account write a privacy-safe audit event: type, time, account ID, actor user ID and plan. No message bodies, no card data.

### B.1 Signed-in information architecture and account menu

**Route map (K63).** Public: `/` Home, `/sample-shop` Sample shop, `/pricing` Pricing, `/help` Help centre, `/sign-in`, `/reset-password`, `/legal/terms`, `/legal/privacy`, `/legal/refunds-and-cancellation`, `/legal/dpa`, `/legal/cookies`. Signed in: `/app` Control room (current shop), `/app/upload`, `/app/products`, `/app/leaks`, `/app/calculators`, `/app/scenarios`, `/app/costs`, `/app/shops`, `/app/team`, `/account/info`, `/account/billing`, `/account/data`, `/app/sample` (sample shop Control room), `/invite/:token`, `/welcome` (first-run). The current shop is part of the address (for example `?shop=<id>` or `/app/s/<shopId>/…`; Development chooses the form) so a refresh keeps the same shop. Unknown routes show a helpful 404 with links to Home and, when signed in, the Control room.

**Header, signed out.** Logo (links Home), **Home**, **Sample shop**, **Pricing** (K60), **Sign in** (quiet), primary **Start 14-day free trial** (K46).

**Header, signed in with no trial or plan yet.** Home, Sample shop, Pricing, primary **Choose a plan**, and the account button.

**Header, signed in on a trial or paid plan.** Home, Sample shop, Pricing; no “Start 14-day free trial” anywhere on any page (K67); the green top-right **account button** labelled with the **business name** (K67). Until a business name is saved it shows the user's first name, then the email as last fallback. Long names truncate with the full name available to screen readers and on focus.

**Account menu** (opens from the account button; keyboard and screen-reader operable; closes on Escape or outside tap):

| Item | Who sees it | Goes to |
|---|---|---|
| Business name, signed-in person's name and email, role badge (Owner or Member), plan badge (for example “Growth · Trial ends 25 Nov”) | Everyone | — |
| **Shop switcher** (list of shops, current one ticked, **Add shop** if allowed) | Scale (trial or paid) | Switches the current shop; Add shop goes to `/app/shops/new` |
| **Info** | Everyone | `/account/info` |
| **Control room** | Everyone | `/app` for the current shop |
| Shops | Owner | `/app/shops` |

| Item | Who sees it | Goes to |
|---|---|---|
| Team | Owner on Pro or Scale; members see read-only | `/app/team` |
| Plan & billing | Owner | `/account/billing` |
| Data & privacy | Owner; members see their own export only | `/account/data` |
| Help centre | Everyone | `/help` |
| Sign out | Everyone | Signs out this device |

On Starter, Growth and Pro the shop name shows in the Control room header with **Rename** for the owner; there is no switcher because there is one shop.

**Settings sections.** The three Settings sections (5) become **Info** (business profile and sign-in), **Plan & billing** and **Data & privacy**. Info replaces “Profile & sign-in”.

**Control room in one click (K67).** From any signed-in page the Control room is one click away: via the account menu and via the logo when signed in (logo goes to `/app` when signed in, Home when signed out).

**Acceptance.** IA-1 Every route above loads directly, survives refresh and back/forward. IA-2 Signed-in trial or paid users see no “Start 14-day free trial” on any page, including public pages, banners and emails. IA-3 The account button shows the business name; it falls back to first name then email only until a business name is saved. IA-4 Menu items match the table per role and plan; hidden items are also refused by the server. IA-5 Control room is reachable in one click from every signed-in page. IA-6 Every navigation opens at the top.

### B.2 Shops and multi-shop (K68)

**Entity.** Shop: id, account, name (1–60 characters, unique in the account), platforms enabled (within tier slots), currency, created, status `active` or `deleting`. Every order, cost, ad, overhead, saved dataset, scenario, result and upload belongs to exactly one shop. Settings that are per account: plan, billing, team, time zone. Settings that are per shop: platforms, currency, tax settings, target margin, FX settings.

**Tier limits.** Starter 1, Growth 1, Pro 1, Scale up to 3 (trial or paid). The monthly unique-order limit is **account-wide** on every plan (one bucket across all shops). Platform slots apply per shop (Starter 1, Growth up to 2, Pro and Scale all 3, while TikTok is coming soon).

**Flows.**

1. **First shop.** Created in first-run (23.5): name and platform. Required before upload.
2. **Add shop (Scale, owner).** Account menu → Add shop, or Shops → Add shop → name, platforms → Create → the new shop opens empty with its own first-run upload prompt. At the limit the button is replaced by “Scale includes up to 3 shops” (no upgrade beyond Scale).
3. **Add shop on Starter, Growth or Pro (owner).** The Add shop action is shown and opens an upgrade explainer: “Add up to 3 shops on Scale (£199/mo).” It never creates a second shop below Scale.
4. **Rename (owner).** Inline; takes effect everywhere at once.
5. **Switch (Scale, everyone).** From the account-button switcher or Shops. Switching changes the current shop in the address, keeps the same page type (for example Leaks → Leaks), and opens at the top.
6. **Remove (owner, Scale, when more than one shop).** Shops → Remove → confirmation states the shop name, the item counts that will be deleted and “This can't be undone”; the owner types the shop name to confirm. The shop's product data is deleted (12.6 scope, backups within 7 days). Order usage already counted this billing month is **not** refunded. The last remaining shop cannot be removed; Start fresh (17.3) empties it instead.
7. **Combined view (Scale).** The Control room offers “All shops” as a read-only combined summary: true profit, revenue and leak £ per shop side by side and in total. The Health Score stays per shop (it is not averaged), so formulas are unchanged.

**Downgrade from Scale.** Applies at renewal (Q27). Before it applies, the owner chooses which one shop stays active. Other shops become **locked** (kept, not visible, not uploadable) and unlock on upgrade. If the owner does not choose, the oldest shop stays active. Locked shops are deleted only when access ends (K39).

**Errors and edge cases.** Duplicate name → inline error. Upload while a shop is being removed → refused with a clear message. A member removed mid-session loses access on next request. Two owners' tabs removing the same shop → second gets “This shop has already been removed”.

**Acceptance.** SH-1 Starter/Growth/Pro cannot create a second shop by any route (UI or API). SH-2 Scale can create, rename, switch and remove up to 3 shops. SH-3 Data never appears in another shop (orders, costs, results, exports, PDF, search). SH-4 The order limit is counted once across all shops; re-uploading the same orders to the same shop does not add usage. SH-5 Removing a shop deletes its data and keeps usage; the last shop cannot be removed. SH-6 Switching survives refresh. SH-7 Scale downgrade locks, not deletes, extra shops; upgrade restores them.

### B.3 Seats, roles and invites (K68)

**Entities.** Membership: user, account, role `owner` or `member`, status `active`, `locked` (over the seat limit after a downgrade) or `removed`. Invite: email, invited by, created, expires (7 days), status `pending`, `accepted`, `expired`, `revoked`. Exactly one owner per account.

**Seat limits.** Starter 1, Growth 1, Pro 2, Scale 5 (trial or paid). Seats used = active members including

the owner + pending invites.

**Permissions matrix.**

| Action | Owner | Member |
|---|---|---|
| View Control room, products, leaks, calculators, scenarios in every shop | Yes | Yes |
| Upload, review import, edit costs, ads and overheads | Yes | Yes |
| Create and edit saved datasets and scenarios; download the PDF (tiers that include it) | Yes | Yes |
| Download my data (CSV) for the account's shops | Yes | Yes |
| Add, rename or remove shops | Yes | No |
| Invite, revoke invites, remove members | Yes | No |
| Edit business Info (business name, country, VAT number, address) | Yes | View only |
| Edit own name, phone, password, Google link | Yes | Yes (own only) |
| Plan & billing: change plan, payment method, invoices | Yes | No |
| Cancel trial or subscription | Yes | No (K50) |
| Start fresh, Clear sample data | Yes | No |
| Transfer ownership | Not in v20 (see below) | No |

**Invite flow.** Team → Invite → email → Send. The server checks the seat limit, the email is not already a member, and the inviter is the owner. SES sends “[Business name] invited you to Margins365” with an Accept button linking to `/invite/:token`. The invitee signs in or creates an account (Google or email) **with the same email**; the email must be verified. Accept → membership `active` → lands in the Control room of the current shop. Wrong email signed in → “This invite is for a different email. Sign out and use [masked email].” Expired or revoked → “This invite is no longer valid. Ask the account owner for a new one.” A person can belong to one account at a time in v20; inviting someone who already belongs to another account shows “This person already uses Margins365 with another business.”

**At the limit.** Invite is disabled with “Your plan includes [n] seats. Pro includes 2, Scale includes 5.”

and, for Starter/Growth, an upgrade link.

**Remove a member (owner).** Confirmation → membership `removed`, sessions ended at once, an email "You no longer have access to [Business name] on Margins365". Their uploads and edits stay with the account.

**Downgrade below current seats.** At renewal the owner chooses who stays; others become `locked` (cannot sign in to this account; told why on sign-in) until an upgrade. If no choice, the most recently added are locked first.

**Ownership transfer** is not offered in v20; the Help centre explains that the owner must keep control of billing. (Product decision: it touches billing identity and cancellation rights and is not needed for launch.)

**Account closure.** When the owner's cancellation reaches access end, every membership ends with the account (K51). Members get the same dated warning email when the owner confirms cancel.

**Acceptance.** ST-1 Seat limits enforced on the server, counting pending invites. ST-2 Invite emails arrive via SES from the margins365.com identity; tokens are single use and expire in 7 days. ST-3 Accept requires a verified sign-in with the invited email. ST-4 Members cannot reach owner actions by UI or API (403). ST-5 Removal ends sessions immediately. ST-6 Downgrade locks, not deletes; upgrade restores. ST-7 Members never see "Cancel subscription".

### B.4 Account profile — Info (K70)

**Sign-up stays short.** Create account asks only: email and password (or Continue with Google), and acceptance of the Terms with a link to the Privacy Policy (K74). Everything else is completed in first-run (23.5) and kept in Info.

**Info fields.**

| Field | Required? | Why (UK GDPR data minimisation) |
|---|---|---|
| Your name | Required | Identify the person signed in and on the team |
| Business name | Required | Account identity, header button, invoices context, invites |
| Country (business location) | Required | Tax and VAT handling, home currency default, legal terms that apply |
| Email (sign-in) | Required | Sign-in, verification, account emails. Changing it needs re-verification |
| Phone number | Optional | Only to reach the owner about the account |

| Field | Required? | Why (UK GDPR data minimisation) |
|---|---|---|
| | | if email fails. Never used for marketing |
| Business address | Optional | Shown on the owner's own records; invoices come from Link |
| VAT number | Optional | Reference for the customer's own records |
| Website or main shop URL | Optional | Context for support |
| Home currency and time zone | Required (defaults from country and browser) | Calculations and dates |
| Linked Google account, password, sign out of all devices | — | Sign-in management (existing 5 / 5.1 rules) |

The live build currently requires phone; v20 makes it optional (minimisation). Validation: name and business name 1–100 characters; phone in international format; VAT number free text up to 20 characters; country from a list. Owners edit business fields; members edit their own name, phone and sign-in only. Changes save with a visible “Saved” confirmation and survive refresh. The data is deleted with the account (12.6).

**Acceptance.** IN-1 Sign-up asks only email/password or Google plus Terms acceptance. IN-2 First-run cannot finish without name, business name and country. IN-3 Optional fields can be left empty. IN-4 Business name immediately updates the account button. IN-5 Email change requires verification before it takes effect. IN-6 Members cannot edit business fields (UI or API).

### B.5 Onboarding and first run

**Steps (each its own route, resumable after refresh or sign-out):**

1. **Verify email** (email sign-ups; Google verified counts, 5).
2. **About your business** (`/welcome`): your name, business name, country. Continue.
3. **Choose a plan** (if the person arrived without one): plan cards with monthly/annual toggle, the founding-offer line while places remain (K72) → Stripe Checkout (12.5A disclosure). Coming back from Checkout lands on step 4. Cancelled Checkout returns to step 3 with “No card was charged.”
4. **Add your first shop**: shop name and platform(s) within the plan's slots.
5. **Upload**: platform file guidance from 17.5 for the chosen platform(s); upload; review import.
6. **Add costs**: product CSV template or type in.
7. **First results**: Control room with the highest-£ fix first (10.1 #5).

The sample shop is always available from the Control room header and from the Sample shop page; it

never consumes allowance and clears under 17 rules. A progress indicator shows steps 4–7 until a first real upload succeeds; it can be dismissed.

**Edge cases.** Leaving mid-way resumes at the first incomplete step. A member joining by invite skips steps 3–4 (the account already has them) and only completes their own name. A trial whose Checkout fails or is abandoned has no subscription; the person stays “signed in, no plan” (23.1 header).

**Acceptance.** ON-1 A new user can go from sign-up to first results without help on phone, iPad and desktop. ON-2 Refresh at any step resumes that step. ON-3 Abandoned Checkout charges nothing and returns to Choose a plan. ON-4 Invited members skip plan and shop steps.

### B.6 Control room

**What it is.** The signed-in workspace for the current shop: `/app`. Order of content (10.1 #5): highest-£ ranked fix, top three leaks with £ monthly impact, Health Score with band and confidence, true profit and net margin, products with verdicts, then detail (calculators, scenarios, costs, uploads). Usage counter (“1,240 of 2,000 orders this billing month”) and trial or founding-price status sit in a quiet strip.

**States.** Empty (no uploads): “Upload your first file” with platform guidance and a link to the sample shop. Sample: labelled Sample data everywhere. Importing: progress and the ability to keep working. Results: as above. Over 80%: notice naming the next plan. At limit: existing results stay; uploads blocked with the 12.4 message. Locked features (after a downgrade): shown with the plan that restores them. Past due: persistent banner with Update card and the deletion warning (12.5). Cancelled: banner with access-end and deletion date and Download my data.

**Scale “All shops” view** as in 23.2.

**Acceptance.** CR-1 One click from any signed-in page. CR-2 Each state above renders as described. CR-3 Highest-£ fix leads on every device. CR-4 Sample data is labelled and never counted.

### B.7 Upload and import

Existing rules stay (6, 12.4, 12.7, 16.1, 17). v20 adds: uploads go to the **current shop**, shown by name on the upload screen; the file picker accepts only the shop's enabled platforms; usage is checked account-wide before import; members can upload; a blocked upload names the shop, the overage and the Upgrade route (owner) or “Ask the account owner to upgrade” (member). Errors: wrong file type, missing required columns, empty file, file too large (Q10 defaults), unknown platform (TikTok until S47), duplicate-only re-upload (“No new orders — nothing counted”).

**Acceptance.** UP-1 Upload lands in the current shop only. UP-2 Account-wide limit and atomic block apply. UP-3 Members see the member version of the blocked message. UP-4 Raw files deleted in every outcome (10.2 #4).

### B.8 Plan & billing (owner only)

**Shows:** plan, interval, status (trial / active / past due / cancelling), next charge date and amount (including the founding price and the date it ends, K72), usage, shops and seats used, invoices (from Link), payment method (Stripe-hosted update), Change plan, and **Cancel trial** or **Cancel subscription** (12.5A).

**Change plan.** Upgrade: immediate, prorated (paid) or immediate with no charge today (trial, K69). Downgrade: at renewal (paid); during a trial it applies immediately to features and to the day-15 charge, and if usage already exceeds the lower limit, new uploads are blocked as in 12.4. Interval change at renewal. Downgrades that exceed new shop or seat limits ask the owner to choose what stays active (23.2, 23.3).

**Members** opening `/account/billing` see “Only the account owner can manage billing.”

**Acceptance.** PB-1 Owner-only by UI and API. PB-2 Amounts match Stripe, including founding prices. PB-3 Upgrade/downgrade timing as above. PB-4 Cancel action visible without hunting.

### B.9 Trial lifecycle (K69, K72)

**States:** `none` → `checkout_open` → `trialing` (day 1–14) → `active` (day 15 charge succeeded) or `past_due` (charge failed; retries up to 14 days) or `cancel_at_period_end` (owner cancelled; access to the original trial end) → `ended` (closed and wiped). One trial per account; per-card prevention where Stripe supports it (recommended default).

**Rules.** The trial runs on the plan the customer chose (K69): Starter trial = Starter features and 500 orders; Growth = Growth and 2,000; Pro = Pro and 5,000; Scale = Scale and 15,000. Changing plan during the trial keeps the same trial end, creates no new trial and charges nothing today. Day 15 charges the chosen plan's price, or the founding price if the account holds a founding place (K72).

**Emails:** trial started (plan, amount, first charge date, founding price and end date if applicable, how to cancel in Plan & billing); reminder 3 days before the end (default, configurable) with the same facts and a link to Plan & billing; first payment receipt (Link); payment failed; cancellation confirmation.

**In-app trial banner (signed in):** “You're on your [Plan] free trial until [date]. Your first payment of £[amount] is on [date]. Cancel any time in Plan & billing.” For founding accounts: “£[founding amount] a month for 6 months, then £[full amount].”

**Acceptance.** TR-1 Each tier's trial grants exactly that tier. TR-2 Day 15 charges the displayed amount once. TR-3 Plan change during trial keeps the end date and charges nothing today. TR-4 Cancelled trials are never charged. TR-5 Reminder content as above.

### B.10 Cancellation (K50, K51, K71)

**Flow (owner, Plan & billing):** Cancel trial / Cancel subscription → **one** confirmation screen with: the 12.5A wording (access end, closure and deletion date, Download my data), an **optional** “Why are you cancelling?” picker (Too expensive; Not using it enough; Missing a feature I need; Hard to use; My

data or files didn't work; Switching to another tool; Business closed or paused; Other) and an optional free-text box (up to 500 characters), then **Confirm cancel** and **Go back**. The reason is never required; Confirm cancel works with it empty; there is no second step and no retention offer.

**After confirm:** in-app confirmation and email (12.5A); members receive the dated warning; the reason is stored (23.13 retention).

**Undo:** “Keep my plan” in Plan & billing until access end if Stripe still shows it active (12.5A).

**Cancellation outside the product.** Link's own subscription tools may let a customer cancel. The webhook (12.10) treats any provider-side cancellation the same way: schedule closure and deletion at the period end, send the same confirmation email.

**Acceptance.** CA-1 Cancel completes with the reason empty in one confirmation. CA-2 Reason options and text are stored when given. CA-3 No email or phone route. CA-4 Provider-side cancel triggers the same schedule and email.

### B.11 Help centre and support (K65)

**Page** `/help`, public. Contents: search-free list of help topics; the **Hard limits & billing** FAQ moved from Pricing (3.2 copy); short answers for sign-in and password reset, shops and seats, uploads and file types, cancelling (Plan & billing only), data and deletion; links to the legal documents; the **Contact us** form.

**Contact form fields:** Name (required), Phone number (optional), Business name (optional), Email (required), Country (required, list), Message (required, 10–5,000 characters). Signed in: name, business name, email and country prefill and stay editable. A short notice: “We use these details to answer your message. Don't include passwords or card details. See our Privacy Policy.” A hidden honeypot field and a minimum fill time protect against bots; no third-party captcha. Limits: 5 submissions per IP per hour and 3 per email per hour (configurable).

**On submit:** server validates → stores the message → sends a notification to **info.marginos@gmail.com** through SES (subject “Margins365 contact: [Name] — [Business name]”, all fields, reply-to set to the visitor's email) → sends a **confirmation** to the visitor's email (“We've received your message”, without their message text, K84; it says “Thank you for contacting us, we aim to respond within 24 hours.”, K88). Then a **pop-up confirmation**: “Thank you for contacting us, we aim to respond within 24 hours.” (title “Message sent”, K88). The pop-up has a Close button, traps focus, and returns focus to the form, which is then cleared. If storage fails: error and keep the content. If email sending fails after storage: show success (the message is stored) and alert the admin; retry sending.

The form is not a cancellation route; if the message mentions cancelling, the copy email includes one line: “To cancel, the account owner uses Plan & billing.”

Stored messages are viewable in an authenticated admin inbox (owner of the business operating Margins365 only) and are deleted 12 months after receipt.

**Acceptance.** HC-1 The FAQ is on `/help`, not on Pricing. HC-2 Form validation, limits and spam protection work signed in and signed out. HC-3 Notification arrives at info.marginos@gmail.com with reply-to the visitor. HC-4 The visitor receives the copy. HC-5 Pop-up appears only after storage succeeds. HC-6 No duplicates on double-click.

### B.12 Notifications and emails

All sent through Amazon SES `eu-north-1` from the **margins365.com** identity (K73), with SPF, DKIM and DMARC passing. Payment receipts and invoices come from Link (Stripe). No marketing emails exist in v20.

| Email | Trigger | To |
|---|---|---|
| Verify your email | Email sign-up, email change | Person |
| Reset your password / Your password was changed / Your sign-in (Google-only) | 5.1 | Person |
| Invitation | Owner invites | Invitee |
| You no longer have access | Owner removes member | Member |
| Trial started | Checkout complete | Owner |
| Trial reminder | 3 days before trial end (default) | Owner |
| Founding price ends soon | 14 days before month 6 ends (K72) | Owner |
| 80% of order limit | First time usage crosses 80% in a billing month | Owner and members |
| Payment failed / final failure | Stripe events | Owner |
| Cancellation confirmation | Cancel confirmed or provider cancel | Owner; dated notice to members |
| Data deleted | Wipe completed | Owner's last email |
| Contact notification / contact copy | Help centre form | info.marginos@gmail.com / visitor |

No email offers cancellation by reply. Every email uses `PRODUCT_NAME` and links to margins365.com only.

### B.13 Data held, retention and findings

| Data | Where | Kept until |
|---|---|---|
| Product data per shop | DigitalOcean London | Access end; backups within 7 days |
| Account, Info, memberships, invites | DigitalOcean London | Account closure; invites 30 days after they end |
| Cancellation reason | DigitalOcean London | Linked to the account until access end, then kept without any account or personal link for reporting |
| Founding place record | DigitalOcean London | Account closure; a count without personal data is kept to honour the 100 limit |
| Contact messages | DigitalOcean London and the info.marginos@gmail.com mailbox | 12 months after receipt |
| Legal acceptance (document, version, time) | DigitalOcean London | Account closure, then as a billing record where needed |
| Billing records | Stripe/Link and our records | As the law requires (UK records: normally 6 years) |

**F1 (live finding, 11 Nov 2026).** The live bundle keeps account and product state (including costs and scenarios) in the browser's localStorage under `marginos.*` keys. v20 requires product data to live server-side; browser storage may hold only UI preferences and a cache that is cleared on sign-out and account closure. Otherwise deletion at access end and per-shop separation cannot be guaranteed.

### B.14 SEO and discoverability (K75)

The public site's search requirements are in the companion **`/workspace/v20.1/Margins365-SEO-v20.1.md`** (SEO spec v20): prerendered HTML for public routes in B.1 and `noindex` for signed-in routes; exact per-page titles, meta descriptions, H1s, canonicals and robots (SEO 5.1); real `<a href>` links; robots.txt and XML sitemap; real 404 status; 301 redirects to `https://margins365.com`; Open Graph/Twitter tags and image; favicon set and manifest; JSON-LD; `lang="en-GB"`; Core Web Vitals targets (LCP < 2.5 s, INP < 200 ms, CLS < 0.1, in line with 15.2.10); Search Console and Bing. **Status: approved by Akthar, 11 November 2026, 14:38 Europe/London.** The free calculators, keyword landing pages and help articles, the Home H1 and analytics are K76–K79 (B.15–B.18). **No competitor comparison page** (not approved). Acceptance: QA suite SEO.

### B.15 Free public profit calculators (K76)

**Approved by Akthar, 11 November 2026, 14:38 Europe/London.** Four public, free, no-sign-up calculators, each on its own landing page (SEO spec 15.1):

| Calculator | Route | Fee presets used (16.2, UK row) |
|---|---|---|
| Etsy profit and fee calculator UK | `/etsy-profit-calculator-uk` | Transaction fee 6.5% and regulatory operating fee 0.48% of item + shipping; payment processing 4% + £0.20 of the order total; listing fee $0.20 per unit sold, converted at the ECB rate; optional Offsite Ads 15% or 12% (capped at $100 per order, converted) counted as **ad spend** |
| Amazon UK fee and profit calculator (FBA and FBM) | `/amazon-fee-calculator-uk` | Referral fee by category from the 16.2 Amazon table, default "Everything else" 15%, minimum £0.25 per item, on the total the buyer pays (Development confirms the fee base on sell.amazon.co.uk and records the source, as 16.2 requires); FBA fulfilment, storage and other Amazon fees are **entered by the user per unit** (no FBA preset exists in 16.2), with a link to Amazon's Revenue Calculator |
| Shopify profit calculator UK | `/shopify-profit-calculator` | Shopify Payments UK online card rate by plan (Basic 2% + 25p default; Grow, Advanced, Plus selectable; Amex/international 3.1% + 25p option) |
| Ecommerce profit margin calculator UK | `/ecommerce-profit-margin-calculator` | No preset: the user enters a percentage fee and a fixed fee per order |

**One calculation engine (mandatory).** The calculators call the **same calculation module and the same fee-preset and tax-rate configuration** as the signed-in product. They do not re-implement any formula. Rules reused, unchanged: revenue, contribution margin and net profit (12.0); product verdict Healthy / Thin / Losing money (12.2); decimal half-up rounding, money to 0.01 and percentages to 0.1%, rounded only for display (12.3); target price, break-even price and the VAT-inclusive "rounded up to the next 0.01" display (12.3); break-even ROAS = 1 ÷ CM % and break-even ACOS = CM % (12.0); input validation (12.7); fee presets and their "last checked" dates (16.2); UK VAT rates (16.3); currency conversion at the ECB rate (section 6). A change to any of these changes the calculators automatically; the 6-monthly preset recheck (12.3) covers them.

**Inputs (one order; defaults pre-filled so the prerendered page shows a worked example):** selling price per unit; quantity (default 1); "Prices include VAT" with VAT rate (default: not VAT-

registered, so no VAT; UK rates from 16.3 when ticked); shipping charged to the buyer; product cost per unit; packaging per unit; shipping cost the seller pays per order (hidden for FBA orders); expected return cost as % of revenue (default 0%); ad spend per order (default £0); "The platform charges me VAT on its fees" (default **on** for Etsy and Amazon when not VAT-registered, **off** for Shopify Payments processing; label: "Check your fee invoices; not tax advice"); the platform options in the table above; optional units sold per month for a monthly projection.

**Outputs:** revenue excluding VAT; each fee line and total fees (VAT on fees as its own line where it applies); return cost; contribution margin (£ and %); ad spend; **true profit per order** (net profit before overheads) and net margin; verdict; break-even ROAS and ACOS; **break-even price** and **target price for a 10% margin** (12.3; the user can change the target margin); optional monthly totals; a **Show the maths** panel listing every line with its rate, base and source link. Above the results: "Estimate based on [platform]'s published UK rates, last checked [date]. Not tax or accounting advice."

**Behaviour.**

- Results update as the user types; changes are announced politely to screen readers (`aria-live`), with no layout shift.
- Calculation runs **in the browser**. Entered numbers are **never sent to the server, stored, put in the URL, or sent to analytics**. A "Copy result" button copies a text summary.
- Invalid input (negative amounts, non-numbers, price of 0) shows the 12.7 message next to the field and hides the results instead of showing nonsense. Return rate is limited to 0–100%.
- If the target price can't be reached (percentage costs + return rate + target margin ≥ 100%), it shows "Not reachable at this margin" (12.3).
- Minimums and caps (Amazon £0.25 minimum referral, Offsite Ads $100 cap) are applied, and the target price is verified by recomputing: the shown target reaches the margin and 1p less does not.
- Calls to action under the results: signed out "See this for every order: start your 14-day free trial" and "Open the Sample shop"; signed in on a trial or paid plan "Go to Control room" (V10: no trial CTA).
- Each page: H1 and metadata from SEO spec 15.1, 600–1,200 words of help text with a worked UK example in £, the fee table with "last checked" date and sources, an FAQ (FAQPage JSON-LD), BreadcrumbList, links to the other calculators, Pricing and the Sample shop. Prerendered (SEO 3). WCAG 2.2 AA, 44 px targets, phone, iPad and desktop (15).

**Golden examples (computed with the spec formulas by `/workspace/v20/src/calc_examples_v20.py`; QA uses them, with the stated example exchange rate of $1 = £0.75 entered manually):**

| Example | Inputs | Expected results |
|---|---|---|
| **Etsy UK** | Not VAT-registered; price £25.00; shipping charged £3.95; product £7.00; packaging £0.60; shipping cost £3.20; returns 2%; no ads; VAT on | Revenue £28.95; fees £4.23 (transaction £1.88, regulatory £0.14, processing £1.36, listing £0.15, VAT on fees £0.71); return cost £0.58; CM £13.34 (46.1%); true profit £13.34 (46.1%), Healthy; |

| Example | Inputs | Expected results |
|---|---|---|
| | fees on | break-even ROAS 2.17×; target price £11.05; break-even price £9.28 |
| **Amazon UK (FBA)** | VAT-registered, prices include 20% VAT; price £19.99; referral 15%; other Amazon fees £3.10 per unit; product £4.50; returns 3%; ads £1.50 per order; VAT on fees off | Revenue £16.66; fees £6.10 (referral £3.00, other £3.10); return cost £0.50; CM £5.56 (33.4%); true profit £4.06 (24.4%), Healthy; break-even ROAS 3.00×; target price £15.83 (incl. VAT); break-even price £13.83 |
| **Shopify UK** | Not VAT-registered; Basic; price £40.00; shipping charged £4.99; product £12.00; packaging £1.00; shipping cost £4.20; returns 5%; ads £8.00 | Revenue £44.99; fees £1.15; return cost £2.25; CM £24.39 (54.2%); true profit £16.39 (36.4%), Healthy; break-even ROAS 1.84×; target price £25.68; break-even price £22.38 |
| **Margin (generic)** | Prices include 20% VAT; price £18.00; fee 12% + £0.30; product £6.00; packaging £0.40; shipping cost £2.95; returns 4%; ads £1.00 | Revenue £15.00; fees £2.46; return cost £0.60; CM £2.59 (17.3%); true profit £1.59 (10.6%), Healthy; break-even ROAS 5.79×; target price £17.85 (incl. VAT); break-even price £15.67 |

**Acceptance.** PC-1 Every golden example gives the expected results exactly. PC-2 The calculators and the signed-in product give the same figures for the same order (shared module). PC-3 No entered value leaves the browser. PC-4 Validation, minimums, caps and "Not reachable" behave as above. PC-5 Presets show their source and "last checked" date. PC-6 Pages meet SEO spec 15.1 and WCAG 2.2 AA.

### B.16 Keyword landing pages and help articles (K77)

**Approved by Akthar, 11 November 2026, 14:38 Europe/London.**

- **Landing pages:** `/profit-leak-checklist` (the six margin leaks, how to spot each in your own orders, what each is worth a month, linking to the Sample shop) and `/multi-channel-profit` (Shopify, Amazon and Etsy in one true-profit view from CSV exports; no store connection). Metadata in SEO spec 15.1. Prerendered, linked from Home, the Help centre and the calculator pages, and listed in the sitemap.
- **Help articles** under `/help/<topic>`: the 10 topics in SEO spec 15.2, about 2 a month. Each has one H1, an "Updated [date]" line, author "Margins365 team", sources for any fee or tax fact, links to related articles, the relevant calculator and Pricing, and BreadcrumbList. Tax content says "Not tax advice"; the VAT article is checked by the accountant before publishing.
- **Accuracy rule:** every fee, tax and product claim matches spec v20 and the 16.2/16.3 tables at publication, with the date checked. Product claims match what the product does today (TikTok stays "coming soon", K53).
- **No competitor comparison page** (not approved). Competitors may be named only where

needed for fact (for example "Amazon's own Revenue Calculator").

- **Acceptance.** LP-1 Pages live, prerendered, with SEO 15.1 metadata, in the sitemap. LP-2 Every fact has a source and date. LP-3 No `/compare` page or comparison content exists.

### B.17 Home H1 (K78)

**Approved by Akthar, 11 November 2026, 14:38 Europe/London.** The Home H1 becomes **"Know your true profit and where it leaks"** (replacing "Stop guessing your e-commerce unit economics."). The supporting sentence below it stays as it is. The Product section headline "See where your profit is leaking." (K55) is unchanged. Exactly one H1 on Home. **Acceptance.** H1-1 Home's only H1 reads exactly as above in the prerendered HTML and on every device, without breaking the hero layout (K48 scaling).

### B.18 Analytics and the consent banner (K79)

**Approved by Akthar, 11 November 2026, 14:38 Europe/London.**

**Provider: Plausible Analytics** (Plausible Insights OÜ, Estonia). Chosen because it sets **no cookies and uses no browser storage**, stores no IP addresses or persistent identifiers (a daily-rotating salted hash counts unique visitors), keeps all visitor data in the EU (Hetzner, Germany; UpCloud, Finland; Bunny CDN, Slovenia) and provides a DPA to every customer (Plausible DPA; EU hosting; compliance). Margins365 is the controller; Plausible is its processor.

**Gating (stricter than the law requires, by Akthar's instruction).** The analytics script is **not loaded and makes no request** until the visitor clicks **Accept analytics**. This works the same for UK and EU visitors. Reject or no choice means no analytics. A Global Privacy Control signal (`Sec-GPC: 1`) is treated as Reject: the banner is not shown and nothing loads, though the visitor can still opt in through Cookie settings.

**Consent banner.**

- Shown on the first visit to any public page, at the bottom, without covering the main heading or blocking use of the page (no cookie wall).
- Text: "We'd like to use privacy-friendly analytics (no cookies, no tracking across sites) to see which pages help people. You can change this at any time in Cookie settings." with a link to the Cookie notice.
- Two buttons of **equal size, weight and prominence: "Accept analytics" and "Reject"**. No pre-ticked boxes; closing the banner (X or Escape) counts as Reject.
- The choice is stored in browser local storage as `m365_consent` (value, notice version, date). Storing the choice is strictly necessary and is listed in the Cookie notice. It is asked again after 12 months or when the Cookie notice version changes.
- **Cookie settings** link in the footer (Legal column) reopens the choice at any time; withdrawing is as easy as giving consent and takes effect immediately (the script is removed and no further events are sent).
- Keyboard and screen-reader operable, focus not trapped, WCAG 2.2 AA, 44 px targets; doesn't cause layout shift (CLS < 0.1).

- Signed-in users see the banner only on public pages.

**What is measured.** Public pages only: `/`, `/sample-shop`, `/pricing`, `/help` and help articles, legal pages, the calculators and landing pages. **No analytics in the signed-in app** (`/app/*`, `/account/*`, `/welcome`, `/invite/*`), on sign-in or reset pages, or in emails. Page views use the canonical URL with no query string. Events (no personal data, no entered numbers): `Calculator used` (property: calculator name), `Start trial clicked`, `Sample shop opened`, `Contact form sent`, `Checkout started`. Never sent: email, names, business names, account or shop IDs, invite or reset tokens, form contents, calculator inputs.

**Data and retention.** Aggregate statistics only. Margins365 deletes site statistics older than 24 months (manual yearly task until automated). Plausible is added to the Privacy Policy recipients and to the DPA page's list of service providers for Margins365's own website (it does not process Customer shop data).

**Legal documents.** The Cookie notice, Privacy Policy and DPA & subprocessors page move to **v20.1** (approved texts in `/workspace/v20/`), published in the **same release** that turns analytics on. Until then the site shows v20.

**Acceptance.** AN-1 No request to Plausible (or any analytics host) before Accept, after Reject, with GPC, or on signed-in pages. AN-2 After Accept, page views and the listed events arrive in Plausible with no personal data or entered values. AN-3 Withdrawal stops sending immediately. AN-4 Banner: equal choices, no pre-ticks, close = reject, re-ask rules, accessible. AN-5 No cookies are set by analytics. AN-6 v20.1 legal texts published with the release.

### B.19 Phones, pop-ups, page position, forms and email delivery (K80–K86)

**Source.** Akthar's iPhone test of the live site on 11 November 2026. K80–K83 and K85 are fixes he asked for. K84 and K86 make his contact and email requests work. Within K84, sending the visitor a **confirmation without their message text** is a Business & Product security recommendation for Akthar to confirm. Live findings are in the v20 change pack under "Live findings behind K80–K86".

#### B.19.1 Every pop-up works on a phone (K80)

Applies to every pop-up, sheet, drawer and confirmation, now and in future. That includes sign in, sign up, verify, profile completion, forgot password and set new password; plans and free trial; Clear sample data; Delete my shop data; Cancel trial / subscription with the optional reason; the Help centre success pop-up; account menu; shop switcher; invite and remove member; the phone navigation menu; the cookie banner and Cookie settings.

- **Fits the visible screen.** A pop-up is never taller than the part of the screen the user can see. It is sized to the visible viewport (not the full-height `100vh` measure) with a small margin. This holds on iPhone Safari with the address bar shown or hidden, in landscape, and while the on-screen keyboard is open.
- **Scrolls inside.** If the content is longer than the screen, it scrolls inside the pop-up. The title and **Close** stay visible at the top.
- **Buttons always reachable.** The primary and secondary buttons (for example **Start 14-day**

**free trial** and **Not now**) can always be reached without zooming. They are never cut off, and never behind the browser toolbar, the home indicator or the cookie banner. Bottom spacing respects the device's safe area.
- **Page behind stays still.** While a pop-up is open the page behind doesn't scroll, including on iOS, and swipes inside the pop-up don't pass through to the page. Closing it returns the page to exactly where it was.
- **On top of everything.** Pop-ups sit above every other layer, including the sticky header and the cookie banner.
- **Plans pop-up.** On a phone, the user can see which plan is selected next to the trial terms and the button, without scrolling back up. The terms box always names the selected plan and its exact price (D-1).
- **Keyboard and screen reader.** Focus moves into the pop-up and stays there. Escape and Close both close it, and focus returns to the button that opened it. A focused form field is never hidden by the phone keyboard.
- **Resilient.** Rotating the device, 200% text size and the largest iOS text size keep every control reachable.

**Site-wide mobile check (K80).** Every public page and signed-in screen is checked at 320, 375, 390, 414 and 430 px wide, on iPad portrait and landscape, and on desktop. Browsers: iPhone Safari (address bar shown and hidden), Android Chrome, Samsung Internet and iPad Safari. Pass means:

- no sideways page scrolling;
- nothing hidden behind fixed bars;
- every button reachable and at least 44 × 44 px;
- forms usable with the keyboard open;
- no pinch-zoom needed for body text;
- in portrait, the sticky header takes no more than about a sixth of the phone screen's height.

**Acceptance.**

- MOB-1: Each listed pop-up, on iPhone Safari (bar shown and hidden), Android Chrome and iPad, can reach its last control. Close stays visible.
- MOB-2: The page behind doesn't move while the pop-up is open, and is in the same place after closing.
- MOB-3: The cookie banner never covers a pop-up control.
- MOB-4: Keyboard open: the focused field and the submit button are reachable.
- MOB-5: Focus is trapped and returned, and Escape works.
- MOB-6: Site-wide mobile check passes on every page and screen.

### B.19.2 The "14 days free" banner is removed (K81)

Remove the sticky banner whose text is exactly **"14 days free. Cancel before day 14 and pay nothing. From £39/mo"**:

- from every page, public and signed in, on every device;

- including its dismiss button and its saved "dismissed" setting.

There is no replacement banner. This supersedes the K43 banner (approved 6 November 2026, 00:34 Europe/Madrid) and the banner lines in 3, 12.5A, 15.3, 15.4, S23 and S46.

**What stays.** The trial terms required before purchase stay where they are now: the Pricing cards, the trial terms in the plans pop-up, Checkout (K43 Option 1 and the K69 disclosure) and Plan & billing. The header keeps its single primary button (K46). Other live lines that contain "Cancel before day 14" are not the banner, so they aren't removed under K81. The signed-in trial status line (12.5B, "You're on your [Plan] free trial until [date]...") is also not this banner and stays.

**Acceptance.**

- BN-1: A text search of the built site and the prerendered HTML finds no "Cancel before day 14 and pay nothing. From £39/mo" and no "14 days free." banner.
- BN-2: The header is the top element on every page, with no empty strip.
- BN-3: The trial terms are still shown on Pricing, in the plans pop-up and at Checkout.

### B.19.3 Every page opens at the top, instantly (K82, fixes K62)

Any change of page shows the new page **at the very top, instantly, with no animated scrolling**, on every device. "Any change of page" covers:

- the header, footer, Start here and Sample shop buttons, and Pricing buttons;
- the account menu;
- links inside FAQs, Help articles and legal pages;
- email links landing on the site;
- the redirect after sign-in and Stripe returns.

**Rules:**

- Smooth scrolling is allowed only for jumps within the same page (for example **Compare plans** to the table on Pricing). It must never apply to a page change.
- The top position holds after the new page finishes loading. Late content (lazy sections, images, fonts) must not push the user down.
- The new page's heading isn't hidden under the sticky header.
- For screen readers, focus moves to the new page's main heading.
- Back and forward may restore the previous position (normal browser behaviour). Refreshing a page may keep the position on that page.

**Acceptance.**

- NV-1: From the very bottom of Home on iPhone Safari, every page change lands at the top with no visible scrolling animation. The position is still the top 2 seconds later.
- NV-2: The same from the bottom of every page, on Android Chrome, iPad and desktop.
- NV-3: In-page jumps still scroll to their target.

- NV-4: Back restores the earlier position.

### B.19.4 Suggest a feature is emailed to info.marginos@gmail.com (K83)

Replaces the Q33 store-only default (S58). Suggest a feature stays **signed in only**.

**On send:**

1. The server checks the text (1–1,000 characters).
2. It stores the suggestion, as today, for the admin list.
3. It sends a notification through SES from the margins365.com identity to **info.marginos@gmail.com**. The recipient is a server setting and is never in the page code.

**The notification:**

- **Subject:** "Margins365 feature suggestion: [Business name] ([Plan])".
- **Body:** the suggestion text; the submitter's name and account email (taken from the session); business name; plan and status (trial or paid); role (owner or member); number of shops; internal account ID; the date and time (Europe/London); and the screen it was sent from.
- **Reply-To:** the submitter's account email.

**Behaviour:**

- **Success** is shown in the page: "Thanks, your suggestion has been sent to the Margins365 team." No promise of a reply, and no copy is sent to the user.
- **Failures.** If storing fails, show an error and keep the text. If storing works but sending fails, show success (the suggestion is stored), raise an admin alert and retry automatically until it is sent.
- **Limits.** 5 per account per hour and 20 per day, held in shared storage. A double tap sends once. HTML is shown as text everywhere.
- **FAQ wording:** 3.2 entry 3 (K87), which begins "Signed in, open Suggest a feature, write a short note and send it. It goes straight to the Margins365 team. We can't promise a reply."

**Legal follow-up (needs Akthar's approval):** the Privacy Policy and DPA list the Gmail mailbox for contact messages only. In the next legal version, add "and feature suggestions" to the Google (Gmail) recipient line, and add a "Feature suggestions" row: account name, email, business name, plan and text; purpose "improve the product"; basis "legitimate interests"; kept 24 months.

**Acceptance.**

- FS-1: A suggestion arrives at info.marginos@gmail.com with every listed field. Reply-To is the submitter.
- FS-2: It is stored and visible in the admin list.
- FS-3: Signed out, the form isn't offered and the server refuses the request.
- FS-4: The limits hold and a double tap sends once.
- FS-5: The SES-failure path shows success, raises an alert and is delivered after the retry.

### B.19.5 Contact us delivers to info.marginos@gmail.com, signed in and signed out (K84; adds to 23.11)

Where this differs from 23.11, this applies.

**Sending:**

- One form and one server route for both states. The server always sends to **info.marginos@gmail.com** (a server setting); the page never chooses the recipient.
- Sent server-side through SES from the margins365.com identity, From name **Margins365**.
- **Notification subject:** "Margins365 contact: [Name] — [Business name]". It contains every field, and **Reply-To is the visitor's email**, so Akthar can reply straight from Gmail.
- **Signed in**, the notification also shows, taken from the session rather than the form: the account email, the business name on the account, plan and status, role, internal account ID, and a flag when the form email differs from the account email. **Signed out**, it is marked "Signed-out visitor".

**Visitor confirmation (security):**

- It is a **confirmation without their message text**. Subject: "We've received your message — Margins365". Body (K88): "Hi [Name], Thank you for contacting us, we aim to respond within 24 hours. You sent your message from the Margins365 Help centre on [date, time, time zone]."
- Add "To cancel, the account owner uses Plan & billing." when the message mentions cancelling.
- Reply-To is info.marginos@gmail.com.
- It contains no message text, phone number or other fields, so the form can't be used to send someone else spam content.
- This replaces "a copy of what they wrote" in 23.11 and HC-4.

**On screen:**

- **Success pop-up.** It is shown in the page, not in the browser's alert box, and only after the message is stored. Title "Message sent"; body exactly "Thank you for contacting us, we aim to respond within 24 hours." (K88). The line under Send shows the same sentence. It has a Close button and follows K80. The form is then cleared.
- **Failures.** If storing fails, show an error and keep everything typed. If storing works but the notification fails, show success, raise an admin alert and retry until it is sent; both emails must eventually arrive. A failed visitor confirmation never blocks success.

**Spam and abuse:**

- A hidden honeypot field and a minimum fill time of 3 seconds. Bot submissions are refused silently.
- Server limits: 5 per IP per hour and 3 per email address per hour, held in shared storage so they survive restarts and work across servers.
- The visitor's IP is taken from Cloudflare's connecting-IP header, never from a value the visitor

can set.
- A neutral "please wait" message when a limit is hit.
- Line breaks are removed from name and email (no header injection).
- No third-party captcha.

**Message length:** 10–5,000 characters, enforced in the page and on the server (live is 4,000).

**Legal follow-up (needs Akthar's approval):** in the Privacy Policy, change "Answer your message and send you a copy" to "Answer your message and send you a confirmation".

**Acceptance.**

- HC-7: Signed out and signed in, each send produces exactly one notification at info.marginos@gmail.com, with Reply-To set to the visitor.
- HC-8: Signed-in notifications carry the account context from the session.
- HC-9: The visitor confirmation has no message text.
- HC-10: The in-page pop-up appears only after storage succeeds.
- HC-11: The honeypot, fill time, limits and injection checks hold.
- HC-12: The failure paths behave as above.

### B.19.6 Forgot password works end to end (K85; adds to 5.1, 16.5 and K57)

**The journey:** Sign in → **Forgot password?** → enter email → neutral message → email → link → set a new password → signed in, with other sessions signed out → "Your password was changed" email. It must work on iPhone Safari, Android Chrome and desktop, including when the link is opened on a different device.

**Requirements:**

- **No browser-only fallbacks** for any account action: sign in, Google sign-in, verification, reset request, set new password or profile save. If the server can't be reached or returns an error, show "We couldn't reach Margins365. Check your connection and try again." and change nothing. Remove the demo routines from the production build.
- **Reset request.** The server always returns the neutral message "If an account exists, we've sent a reset link." for any well-formed email, with similar timing. If SES fails, the server keeps the request, retries, raises an alert and logs it for Development; the user still sees the neutral message, so nothing reveals whether an account exists.
- **Reset link.** The server builds it only from a fixed setting (`https://margins365.com`), **never from a value the browser sends**. It points to a real `/reset-password` page (today that address is 404). The token is removed from the address bar once the page loads, never sent to analytics and never leaked in the referrer.
- **K57 / Q34 rules unchanged:**
- the link lasts 60 minutes and works once;
- older links stop working;
- 3 requests per email and 10 per IP per hour, held in shared storage;
- Google-only accounts get "Your Margins365 sign-in";

- a successful reset signs out every other session and sends "Your password was changed".
- **Email copy:** the brand is one word (the server text still says “Margins 365”). No email asks the reader to "reply to this email", because margins365.com has no inbox. Point to the Help centre instead.

**Acceptance.**

- PR-1: The full journey works for a real test account on the three platforms.
- PR-2: With the server blocked, every account action shows the error and creates no local session or token.
- PR-3: A reset requested with a forged origin still produces a margins365.com link.
- PR-4: `/reset-password` loads and refreshes. The token is gone from the address bar.
- PR-5: An SES failure still shows the neutral message, raises an alert, and the email arrives after the retry.
- PR-6: The K57 limits, expiry, single use and the Google-only email all behave as specified.

### B.19.7 Email sending is set up and proven before release (K86; adds to 20.5.4 and 23.12)

Development does this with Akthar. It blocks release of K83–K85 and every email in 23.12.

1. **SES eu-north-1:** the margins365.com domain identity shows **Verified**. Easy DKIM (3 CNAME records added at the domain's DNS host, GoDaddy) shows **Successful**. The custom MAIL FROM `mail.margins365.com` shows **Successful** (its MX and SPF are already published).
2. **Production access** is granted (out of the sandbox), with a daily quota and sending rate that cover peak use. If the account is still in the sandbox, request production access; AWS asks for the use case, how bounces and complaints are handled and how recipients opted in.
3. **Bounces and complaints** go to a notification destination. Bounced and complained addresses are flagged and not mailed again, and the rates stay below AWS's review levels (bounces 5%, complaints 0.1%).
4. **DNS:** - publish an apex SPF record (`v=spf1 include:amazonses.com ~all`); - keep DMARC at `p=none` but add a reporting address Akthar reads (`rua=`), then move to `p=quarantine` after 2–4 weeks of clean reports.
5. **From and Reply-To:** - From is on margins365.com (for example no-reply@margins365.com), with the name "Margins365". - margins365.com has no inbox (no MX), so Reply-To is set on every email: notifications to Akthar → the sender; everything sent to customers → info.marginos@gmail.com. - No marginos.online identity is used for sending.
6. **Proof before QA.** Send one of each email (verify, reset, Google-only sign-in, password changed, contact notification and confirmation, suggestion notification, invite) to Gmail, Outlook and iCloud. Each must show SPF pass, DKIM pass with `d=margins365.com`, DMARC pass and aligned, and land in the inbox rather than spam. Send one more to an **unverified external address** to prove production access. Attach the SES console screenshots (identity, DKIM, MAIL FROM, account dashboard) to the QA handover.

**Acceptance.**

- ES-1: The identity, DKIM and MAIL FROM all show verified or successful.
- ES-2: Production access is shown on the account dashboard.
- ES-3: Every listed email passes SPF, DKIM and DMARC at three providers.
- ES-4: Bounce and complaint handling has been tested with the SES mailbox simulator.
- ES-5: The apex SPF and DMARC reporting records are published.

### B.20 FAQ on Pricing and in the Help centre (K87)

**Source.** Akthar, 11 November 2026: “Copy all these questions to Help center.” The Hard limits & billing FAQ shown on the live Pricing page (14 questions) appears in full in the Help centre **and stays on Pricing**. This supersedes the K65 “move”.

**One source.** The 15 entries in 3.2 are the 14 live questions plus the approved “Is there a founding offer?”, which was missing from the live list. They are held once, each with an ID, question, answer, group and order. Pricing, the Help centre, their prerendered HTML and their FAQPage JSON-LD are all generated from that source. Editing one answer changes it everywhere. Neither page keeps its own text.

**Pricing.** Heading “Hard limits & billing FAQ”. All 15 entries in the 3.2 order, shown as an accordion. A line under the list: “More help, and our contact form, in the Help centre.” The buttons under the FAQ follow K61, K66 and K67:

- signed out: **Start 14-day free trial**, **Open Sample Shop** (shop icon, K66), **Sign in**;
- signed in without a plan: **Choose a plan** and **Open Sample Shop**;
- on a trial or paid plan: **Go to Control room** and **Open Sample Shop**.

There is no trial button for trial or paid users, and no Sign in or Account button when signed in (the header has the account button). The stale label **“View sample report” is retired** (K60 rename).

**Help centre (`/help`).** Section “Hard limits & billing” holds the same 15 entries under five group headings, in this order. The number in brackets is the 3.2 entry number.

1. **Getting started:** - How do I use this platform? (1) - What exactly is needed to get started? (2) - Do you connect to my store? (11)
2. **Trial, plans and billing:** - What happens after the 14-day trial? (5) - Is there a founding offer? (6) - Can I change plan? (12) - What happens on annual plans? (15) - Does the price include VAT? (13) - Can I cancel anytime? (4)
3. **Order limits, shops and seats:** - How do order limits work? (14) - What happens if I hit my order limit? (9) - What are shops? (7) - What are seats? (8)
4. **Data and privacy:** Is my data safe, and where is it stored? (10)
5. **Feedback and contact:** How can I recommend a new feature I want to see? (3), followed by a **Contact us** link to the form on the same page (`/help#contact`).

A separate “Sign-in and account” section keeps the two Help-only answers from 23.11, which aren't in the Pricing list:

- **How do I sign in?** Use Continue with Google, or your email and password. You need to verify your email before you upload files or start a trial.
- **I forgot my password.** Tap Forgot password? under the password field and enter your email. We'll send a link that works once, for 60 minutes. If you signed up with Google, use Continue with Google instead.

**No duplicates.** The four Help-only questions on the live Help centre are retired, and their content is folded into the single source:

| Retired question | Folded into |
|---|---|
| “Can I cancel anytime?” (a duplicate) | 4 |
| “What happens during the free trial?” | 5 |
| “What are the unique-order limits?” | 14 |
| “How many shops and seats do I get?” | 7 and 8 |

Each question appears once per page.

**Accordion.**

- Every answer starts closed. A tap, click, Enter or Space opens or closes it, and several can be open at once.
- Each question is a button with `aria-expanded`, and targets are at least 44 px.
- Every entry has an anchor (`/help#faq-<id>`, `/pricing#faq-<id>`). Opening an anchor link opens that answer and scrolls to it (an in-page jump, so smooth scrolling is allowed, K82). The answer stays open after a refresh.
- Answer text is in the prerendered HTML even when closed (K75).

**Links.**

- **Suggest a feature** (entry 3): signed in, it opens the Suggest a feature box in the account area; signed out, it goes to Sign in and then returns to that box.
- **Contact us**: goes to the Help centre form, with the form in view.
- **Page position:** every link to another page opens it at the top (K82).

**Answer reconciliation (K87).** The live answers differ from the approved 3.2 copy. 3.2 now applies:

- The “sample report” wording becomes Sample shop (K60).
- “We save it for review” becomes the K83 wording.
- After the trial: “before day 14” becomes “before your trial ends (date shown at Checkout and in Plan & billing)”. This matches the dated trial terms and drops the retired banner phrase (K81).

- The founding offer is added, with pence and the annual prices (K72, D-1).
- Data: SES is located in the EU (Stockholm) (K36).
- Shops and seats: the repeated sentences are removed.
- New approved copy for “How do order limits work?” and “What happens on annual plans?”: the trial is the plan you choose (K69); founding is 25% off year 1 on annual plans; order limits reset monthly; cancelling is in Plan & billing only (K50).

**Acceptance.**

- FQ-1: The same 15 questions and answers, word for word, on Pricing and the Help centre. Changing one answer in staging updates both pages and the JSON-LD.
- FQ-2: Help centre groups and order as listed, with no duplicate questions.
- FQ-3: The accordion behaves as specified (keyboard, screen reader, anchors, refresh).
- FQ-4: The Suggest a feature and Contact us links work signed in and signed out.
- FQ-5: The Pricing FAQ buttons follow the state rules, and “View sample report” is gone.
- FQ-6: Every answer passes the HELP-29 content audit.

### B.21 Contact reply wording and cancellation that really cancels (K88, K89, K90)

**Akthar's request, 11 November 2026 (Europe/London):** “Change the message to ‘Thank you for contacting us, we aim to respond within 24 hours’ … When someone cancels from our platform do they receive any email confirmation or pop up message. Does our cancellation work? … How do we confirm if has been done?”

#### B.21.1 K88 — Contact us reply wording

**What the live site shows today (checked 11 Nov 2026, 20:00):** the pop-up is titled “Message sent” and says “Thanks — we have your message. We read every message, but we can’t promise a reply time.” The line under the Send button says “Thanks — we have your message.” The form intro says “We read every message. We don’t promise a reply time. Do not use this form to cancel.”

**Required copy, word for word:**

| Place | Text |
|---|---|
| Pop-up title | Message sent |
| Pop-up body | Thank you for contacting us, we aim to respond within 24 hours. |
| Line under the Send button after success | Thank you for contacting us, we aim to respond within 24 hours. |
| Form intro | We read every message and aim to respond within 24 hours. Do not use this form to cancel. |

| Place | Text |
|---|---|
| Visitor confirmation email (subject unchanged: “We've received your message — Margins365”) | Hi [Name], Thank you for contacting us, we aim to respond within 24 hours. You sent your message from the Margins365 Help centre on [date, time, time zone named]. (Plus “To cancel, the account owner uses Plan & billing.” only when the message mentions cancelling.) |

**Rules:**

- The words “we can’t promise a reply time” and “We don’t promise a reply time” are removed everywhere (pop-up, intro, email, Help centre text). Nothing else in the contact flow changes: the pop-up still appears only after the message is stored, has a Close button and follows K80; the confirmation still contains no message text (K84).
- It is an **aim, not a guarantee**. It is not written into the Terms as a promise, and it is not a plan feature: the comparison table and pricing cards still have no Support target row and no “priority” support (K41 otherwise stands).
- **Legal and FAQ check (done 11 Nov 2026):** the Terms, Refunds & cancellation, DPA and Cookie Notice contain no reply-time statement, so nothing changes there. The Privacy Policy line “We reply within one month” is about data-rights requests (the legal deadline), not the contact form, and stays. The FAQ (3.2) has no contact reply-time line. 3.2 entry 3 and the Suggest a feature form say “We can’t promise a reply” about **feature ideas**, not the contact form; they are unchanged unless Akthar asks.
- **Operational:** someone must read info.marginos@gmail.com at least once a day, including weekends, for the 24-hour aim to be true.
- **This reverses part of K41 (6 Nov 2026),** which removed all published response times. Akthar asked for this change directly on 11 Nov 2026.

### B.21.2 K89 — Cancellation must cancel in Stripe, and confirm it

**Finding (checked 11 Nov 2026, 19:30–20:15, live site and code):** cancellation does **not** work.

| Check | Result |
|---|---|
| What Confirm cancel does in the live app | It saves the reason in the browser (`m365_cancel_reasons`) and changes the plan state **in the browser only** (`canceled_access` with an end date). It sends nothing to the server. |
| Server routes in the live app and the server code | Sign-in, checkout, contact, feature suggestions, founding, shops, team and the Stripe webhook. **There is no cancel route.** The server never asks Stripe to cancel; it only reads subscriptions. |
| Probe of likely cancel addresses (`/api/billing/cancel`, `/api/subscription/cancel`, `/api/cancel`, `/api/billing/portal` and | Every one returns 405, the same as a made-up address. None exist. |

| Check | Result |
| --- | --- |
| 4 others) | |
| What the customer sees | The message “Cancellation confirmed. You keep access until … Download your data before then.” appears as small grey text in the **Profile & sign-in** card, above the Plan & billing card where Cancel was pressed, so on a phone it is off screen. There is no pop-up. |
| Email | None. No cancellation email exists in the code. |
| Effect | The Stripe subscription stays **Trialing** with an upcoming invoice. **The card will be charged when the trial ends.** In another browser, or after the server refreshes the account, the app shows the trial as still active. |

The spec already required a server-side cancel (12.5A, CAN-07, CAN-08, EML-11; QA gap G8 flagged it). It was not built. K89 makes the requirement exact.

**1. Server cancel (owner only).** Confirm cancel calls one server route, for example `POST /api/billing/cancel`. It checks the session is the owner, then updates the Stripe subscription with `cancel_at_period_end: true` (trial: it ends at the trial end; paid: at the end of the paid period) and an idempotency key, so double taps cancel once.

**2. Check before saying it worked.** After the update, the server reads the subscription back from Stripe and checks: `cancel_at_period_end` is true (or the status is `canceled`), and Stripe's upcoming-invoice preview returns **no invoice to be paid**. For a trial, this is the proof that the card will not be charged. Only then does it record the cancellation and answer success. It stores the Stripe subscription ID, `cancel_at`, the check time and the result.

**3. If anything fails, never claim success.** If the server, Stripe or the check fails, nothing changes in the app and a pop-up says: “We couldn’t cancel your [trial/subscription]. Nothing has changed — you will still be charged on [date] unless you cancel. Please try again.” with **Try again** and **Close**. The browser never sets a cancelled state by itself.

**4. Confirmation pop-up (in the page, follows K80, Close button):**

- Title: “Your trial is cancelled” (paid: “Your subscription is cancelled”).
- Body (trial): “Your [Plan] trial is cancelled. You won’t be charged. You keep access until [date, time, time zone]. On that date your account closes and your data is permanently deleted — download it before then. Reference: [CXL-reference]. We’ve emailed a confirmation to [owner email].”
- Body (paid): “Your [Plan] subscription is cancelled. No further payments will be taken. You keep access until [date, time, time zone]. …” then the same last sentences.

- Buttons: **Download my data** and **Close**.

**5. Confirmation email (SES, from Margins365, Reply-To info.marginos@gmail.com), sent once, only after step 2 succeeds:**

- Subject (trial): “Your Margins365 trial is cancelled — you won’t be charged”. Paid: “Your Margins365 subscription is cancelled”.
- Body includes: cancellation reference; plan (and monthly or annual); date and time cancelled; access until (date, time, time zone); “No further charges will be taken” (trial: “You will not be charged”); data deletion date (the same as access end, K39/K51); Download my data link (Plan & billing); how to keep the plan before that date (Resubscribe). Plain-text version; passes SPF, DKIM and DMARC.
- It does not ask the customer to reply to confirm. If sending fails, the cancellation still stands; the server retries and alerts the admin.
- Team members get the existing dated notice (23.12). The trial reminder email (12.5A) is not sent after a cancellation.

**6. Plan & billing shows the state from the server, every time.** A clear status line: “Cancelled — access until [date, time, time zone]”, the reference, “You won’t be charged” (paid: “No further payments”), and a Stripe line: “Stripe: cancels on [date], no upcoming invoice” (or “Stripe: cancelled”). It reads the server record, not the browser, so it is the same on every device and after signing out and in. The Cancel button is replaced by **Resubscribe**.

**7. Resubscribe.**

- Before access ends: **Resubscribe** (“Keep my plan”) asks for one confirmation stating the charge date and amount, then sets `cancel_at_period_end: false` in Stripe. The trial or period continues with the same end date. It does not start a new trial. A pop-up and an email confirm it.
- After access ends: the account is closed (K51). The person can start again with a new account through Checkout; a second free trial is not given (one trial per account, and per card by default, as in 12.5 and K40).

**8. Audit log.** Every attempt writes one entry: time, account ID, user, role, plan, Stripe subscription ID, action (requested, confirmed, failed, resubscribed), `cancel_at`, the result of the step 2 check, reference, and IP. Only admins can read it. It is kept with the billing records (23.13).

**9. Stripe-side changes stay in sync.** The webhook (`customer.subscription.updated` and `deleted`) applies the same state when the subscription is cancelled or resumed in Stripe or Link: it records the cancellation, sends the same email once and shows the same status. When the subscription ends, the account closes and the data wipe runs (K39/K51). It must **not** set a “free” plan (G9; the Free plan was retired).

**Acceptance.** CX-1 Confirm cancel changes the Stripe subscription (`cancel_at_period_end` true or `canceled`) with no upcoming invoice. CX-2 The pop-up appears only after that check passes. CX-3 One email with every field above. CX-4 Plan & billing shows “Cancelled — access until …” and the Stripe

line on any device. CX-5 A failure shows the failure pop-up and changes nothing. CX-6 Resubscribe works before access ends without a new trial. CX-7 Every attempt is in the audit log. CX-8 A cancel done in Stripe produces the same state and email. CX-9 No charge is taken at trial end for a cancelled trial.

### B.21.3 How Akthar checks a cancellation today (until K89 is built)

1. Open the Stripe Dashboard. Use **Test mode** if the test trial was made with a test card, otherwise live mode.
2. Go to **Customers**, search for the email used for the trial, and open the subscription.
3. **Not cancelled** looks like this: status **Trialing**, no “Cancels [date]” label, and an **Upcoming invoice** showing the plan amount on the trial-end date. With today's build this is what you will see, because the app never told Stripe.
4. To stop the charge now: on that subscription choose **Actions → Cancel subscription**. Pick **At end of current period** (keeps access until the trial ends; the status then shows “Cancels [date]”) or **Immediately** (status **Canceled**). Either way, check that the **Upcoming invoice** section is gone. That is the proof no charge will be taken.
5. In the app: sign in from a private window or another device and open Plan & billing. If it still shows **Cancel trial** and the trial end date, the app did not record the cancellation. (With today's build, cancelling in Stripe **Immediately** may make the app show a retired “free” plan, gap G9.)
6. After the trial-end date, Stripe **Payments** should show no charge for that customer.

### B.21.4 K90 — Trial-start confirmation email and on-screen confirmation

**Akthar's request, 11 November 2026 (Europe/London):** “When someone starts or cancels a trial we need to send them an email confirmation.” The cancel email is K89 (23.21.2). K90 is the start email.

**Finding (checked 11 Nov 2026, live site and server code):** no trial-start email is sent. The only email the server sends through SES is email verification. The Stripe webhook (`checkout.session.completed`) saves the plan and sends nothing. On return from Checkout (`?checkout=success`) the app refreshes the account and opens it, with no confirmation of the trial, its end date or the first charge. 12.5A, CHK-07 and EML-05 already required the email; it was not built.

**1. When it is sent.** Only after the server has confirmed the trial: the `checkout.session.completed` webhook has been processed, the subscription has been read back from Stripe with status `trialing` and a `trial_end`, and the account record is saved. It is sent **once per subscription** (idempotent on the Stripe subscription ID), through SES, from Margins365, Reply-To info.marginos@gmail.com. It is **never** sent if Checkout is abandoned or cancelled, payment-method setup fails, the webhook fails, or Stripe does not show a trial. If SES fails, the server retries and alerts the admin; the trial still stands.

**2. Subject:** “Your Margins365 [Plan] trial has started — first charge on [date]”.

**3. Body (word for word, filled in; amounts to the penny, including VAT; dates with time and time zone named):**

- “Your 14-day free trial of [Plan] ([monthly/annual]) started on [start date, time, time zone]. You pay nothing today.”
- “Your trial ends on [trial end date, time, time zone].”
- “Unless you cancel, we will charge £[amount] including VAT on [first charge date] for your [monthly/annual] [Plan] plan.”
- Founding accounts (K72), monthly: “You have a founding place: £[founding amount] a month for your first 6 monthly payments, then £[full amount] a month.” Annual: “Your first year is £[founding annual amount], then £[full annual amount] a year.” The first charge amount above is the founding amount.
- “Your plan includes [500 / 2,000 / 5,000 / 15,000] unique orders per billing month, shared across all your shops. We warn you at 80%.”
- “To cancel, open Plan & billing and choose Cancel trial before [trial end date]. It takes one click and you won't be charged. Cancelling is only in the platform; replying to this email does not cancel.” With a button that opens Plan & billing.
- “We'll email you a reminder 3 days before you're charged.”
- Reference: [TRL-reference]; link to the Terms and Refunds & cancellation versions accepted at Checkout (LEG-20).
- Plain-text version; passes SPF, DKIM and DMARC. No “Pro trial” wording (K69).

**Prices it must use (including VAT):** monthly Starter £39.00, Growth £79.00, Pro £129.00, Scale £199.00; founding monthly £19.50, £39.50, £64.50, £99.50 for the first 6 monthly payments; annual £390.00, £790.00, £1,290.00, £1,990.00; founding annual first year £292.50, £592.50, £967.50, £1,492.50. The amounts are taken from the Stripe subscription and price, not typed into the template.

**4. On-screen confirmation.** On return from Checkout the app asks the server for the confirmed trial (it may wait up to 30 seconds for the webhook). When confirmed, an in-page pop-up (K80, Close button):

- Title: “Your 14-day free trial of [Plan] has started”.
- Body: “Your trial ends on [date, time, time zone]. Unless you cancel, we'll charge £[amount] including VAT on [date] (founding: then £[full amount] a month / a year). Your plan includes [limit] orders a month. Cancel any time before [date] in Plan & billing. We've emailed a confirmation to [email].”
- If the trial is not yet confirmed after 30 seconds: “We're still confirming your trial with our payment provider. No charge has been taken. We'll email you as soon as it's confirmed.” It never says the trial has started until the server confirms it.
- Plan & billing then shows the trial, the end date and the first charge (12.5A) on every device.

**5. Audit.** The trial start and the email send (sent, retried, failed) are logged with the account, plan, Stripe subscription ID and reference.

**Acceptance.** TS-1 One email after a confirmed trial, with every field above. TS-2 No email when Checkout is abandoned, cancelled or fails. TS-3 Founding and normal amounts correct to the penny for all 4 plans, monthly and annual. TS-4 The pop-up appears only after the server confirms the trial. TS-5 Webhook replays send no second email.

## Files

- `/workspace/v20.1/Margins365-v20.1-Changes.md` and `.pdf` (this pack, version 20.1)
- `/workspace/v20.1/Margins365-Spec-v20.1.md` and `.pdf`
- `/workspace/v20.1/Margins365-Terms-v20`, `-Privacy-Policy-v20`, `-Refunds-and-Cancellation-v20`, `-DPA-and-Subprocessors-v20`, `-Cookie-Notice-v20` (`.md` and `.pdf`)
- `/workspace/v20.1/Margins365-SEO-v20.1.md` and `.pdf` (K75–K79, SEO and discoverability)
- Cookie notice, Privacy Policy and DPA & subprocessors are now **v20.1** (K79), in the same files
- Calculator golden examples: `/workspace/v20/src/calc_examples_v20.py` and `calc_examples_v20_results.txt`
- QA prompt (written separately): `/workspace/v20.1/Margins365-QA-Prompt-v20.1` (now includes suite SEO)
- K88–K89 working files (spec section, change text, QA rows, apply script): `/workspace/v20/src/k88/`
- v19 files are unchanged archives.